A1) Benefits of pentesting	Manage risk. Increase business continuity. Minimise client-side attacks. Protect clients, partners and third-parties. Comply with regulation.
A1) Pentest structure	Reconnaissance (i.e. find live hosts, sweeping, find services, scanning, banner matching, find vulnerabilities). Target prioritisation (e.g. assess servers rather than printers). Testing of services and exploitation if applicable. Consult/Confirm with customer if ok to exploit. Inform customer of any high risk issues that need addressing immediately.
A1) Project Lifecycle	Data Gathering / Scoping / Briefing. Testing. Report Writing. Debriefing
A2) Computer Misuse Act 1990	

The Act defines 3 specific offences: 1. Unauthorised access to computer material (that is, a program or data). 6 months or Level 5 fine (£5000 currently). 2. Unauthorised access to a computer system with intent to commit or facilitate the commission of a serious crime. 5 years, max fine. 3. Unauthorised modification of computer material. 5 years, max fine. In general: You must not test a system without prior authorisation (e.g. as agreed in written scope/contract). You should never test without informing the client beforehand. Amended by Part 5 of Police and Justice Act 2006.

A2) Police and Justice Act 2006

An amendment and update to the Computer Misuse Act 1990 in Part 5 of the Police and Justice Act 2006 are: Section 35. Unauthorised access to computer material. Section 36. Unauthorised acts with intent to impair operation of computer, etc. Section 37. Making, supplying or obtaining articles for use in computer misuse offences. Section 38. Transitional and saving provision. In general: Part V includes a few sections on Computer Misuse Act 1990. Provision for DoS as an offence. Increased penalties. Making available tools to the Internet. Dual-use tools liable.

A2) Human Rights Act 1998

Lots of general human rights involved such as right to marry, discrimination, privacy, slavery, guilty etc. Human Rights Act 1998 is relevant to Computer usage as: "Protects the right of individuals against unreasonable disruption of and intrusion into their lives, while balancing this individual right with those of others." In general: Article 8: Right to respect for private and family life. Right to privacy. With Acceptable Usage Policy (AUP), you waive the right to privacy on network.	
A2) Data Protection Act 1998	In general: Deals with PII (Personal Information ID). Data about identifiable users should only be used for the purpose intended. Should not make a local copy (e.g. HR Database)
A2) Handling Data (6 catergories)	

Data classification set by uk.gov. Important for CHECK member to know the protective marking of test/report. 1. NPM — Non Protective Marking. 2. PROTECT — Not sensitive enough to make classification. Sensitive but not high risk. 3. RESTRICTED — Pentests are usually RESTRICTED as a minimum 4. CONFIDENTIAL — (Prejudical). 5. SECRET — (Serious Injuries). 6. TOP SECRET (EGD).	
A4) 5 Principles of Risk Management	Assess risk and determine needs. Establish a central management focus. Implement appropriate policies and related controls. Promote awareness. Monitor and evaluate policy and control effectiveness.
A3) Sensible scoping questions (7)	

1. What technologies are being used? 2. Can we get access to the application (Web Application)? 3. How many users are there? 4. How many pages are there? Are they dynamic or static? 5. What are you expecting us to find? 6. Will this be a white box or black box test? 7. Will the testing be onsite or remote?	
B1) OSI	Open Standards Interconnection (OSI) developped by International Standards Organisation (ISO)
B1) OSI Model. What and stages?	Model is set of 7 layers that define the different stages that data must go through to travel from one device to another over a network. {7} Application, {6} Presentation, {5} Session, {4} Transport, {3} Network, {2} Data Link, {1} Physical. Higher layers more specific, lower layers more generic.

	Please Do Not Tell Sales People Anything.
B1) Physical Layer	Physical layer defines electrical and physical specifications for devices, i.e. relationship between a device and a transmission medium (e.g. copper or fibre optical cable, Shielded/unshielded twisted pair, 10Base-2, 10Base-T, 100Base-TX, 1000B-T, RJ45, Coaxial, Fibre-optical cables, Copper cables)
B1) Data Link Layer	Data Link layer provides means to transfer data between network entities using a common addressing format. Data Link layer has Logical Link Control (LLC) sublayer for multiplexing several network protocols (e.g. IP, IPX, Decnet and Appletalk) to coexist in multipoint network. Data Link layer has Media Access Control (MAC)

	sublayer for addressing and terminal/network nodes to communicate within a multiple access network. MAC address, PPP, HDLC, ADCCP.
B1) Network Layer	Network layer provides means of transferring data from a source host on one network to a destination host on a different network. IP Address, ARP, IPv4, IPv6, ICMP, IPX, RIP, IKE.
B1) Transport Layer	Transport layer provides transparent transfer of data using connection-oriented data stream support, reliability, flow control, and multiplexing. Port Number, TCP, UDP, SCTP.
B1) Session Layer	Session layer provides mechanism for opening, closing and managing a session between end-user application processes, i.e., a semi-permanent dialogue. SOCKS, TLS-PSK, TLS-SRP.
B1) Presentation Layer	

Presentation layer is responsible for the delivery and formatting of information to the application layer for further processing or display. MIME, Netware Core Protocol, XML.	
B1) Application Layer	Application layer is outermost layer where user interact directly with the software application. FTP, SSH, Telnet, SMTP, IMAP, POP, HTTP, HTTPS, RTP, BOOTP, SNMP, NTP.
B1) TCP/IP Model Layers	TCP/IP model is basically a shorter version of the OSI model. Consists of four instead of seven layers. Application, Transport, Network and Link. TCP Application layer is like Application, Presentation and Session of OSI. TCP Transport aka 'Host-to-host transport' is Transport in OSI. TCP Network aka 'Internet Layer' is Network OSI. TCP

	Link aka 'Network Access' is Data Link and Physical OSI.
B1) TCP/IP Transport and Application Layer	Transport Layer is a convenient application programming interface to internet hosts. Application Layer contains all protocols and methods that fall into the realm of process-to-process communications across an IP network.
B1) IPv4	IPv4 uses a 32-bit address for its Internet addresses. That means it can provide support for 2^32 IP addresses in total â around 4.29 billion
B1) IPv6 Size and Advantages	IPv6 utilizes 128-bit Internet addresses. No more NAT. No more private address collisions. More efficient, many other benefits. Leading zeros can be omitted. The double colon (::) can be used once in the text form of an ad-

	dress, to designate any number of 0 bits.
B1) TCP Characteristics (3)	1) Transmission Control Protocol/Internet Protocol. 2) It is specifically designed as a model to offer highly reliable and end-to-end byte stream over an unreliable network. 3) A TCP connection is established with the help of three-way handshake. It is a process of initiating and acknowledging a connection. Once the connection is established, data transfer begins, and when the transmission process is finished, the connection is terminated by the closing of an established virtual circuit. The connection is full duplex, and both sides synchronize (SYN) and acknowledge (ACK) each other. The exchange of these four flags is performed in three steps—SYN, SYN-ACK, and ACK

B1) UDP Characteristics	1) User Datagram Protocol (A datagram is a transfer unit associated with a packet-switched network.) 2) Datagram oriented protocol. It is used for broadcast and multicast type of network transmission. 3) The UDP protocol works almost similar to TCP, but it throws all the error-checking stuff out, all the back-and-forth communication and deliverability. UDP uses a simple transmission method without implied hand-shaking dialogues for ordering, reliability, or data integrity.
	1) TCP is a connection-oriented protocol, whereas UDP is a connectionless protocol. 2) The speed for TCP is slower while the speed of UDP is faster. 3) TCP uses handshake protocol like SYN, SYN-ACK, ACK while UDP uses no handshake protocols. 4) TCP does

B1) TCP vs UDP (6)	error checking and also makes error recovery, on the other hand, UDP performs error checking, but it discards erroneous packets. 5) TCP has acknowledgment segments, but UDP does not have any acknowledgment segment. 6) TCP is heavy-weight, and UDP is lightweight.
B1) ICMP	1) The Internet Control Message Protocol (ICMP) is a network layer protocol used by network devices to diagnose network communication issues. 2) The primary purpose of ICMP is for error reporting. ICMP is mainly used to determine whether or not data is reaching its intended destination in a timely manner. 3) Unlike the Internet Protocol (IP), ICMP is not associated with a transport layer protocol such as TCP or UDP. This makes ICMP a connectionless protocol: one device

	does not need to open a connection with another device before sending an ICMP message. Normal IP traffic is sent using TCP, which means any two devices that exchange data will first carry out a TCP handshake to ensure both devices are ready to receive data. ICMP does not open a connection in this way. The ICMP protocol also does not allow for targeting a specific port on a device.
B1) ICMP Probing/Ping sweep	Type 8 (Echo Request) - used to perform ping sweeping in order to determine whether hosts are accessible: root@kali:~# ping 192.168.51.29. Can use Nmap to perform ping sweep across a whole network IP range: nmap -sP 192.168.51.0/24
B1) ICMP Types	

Type 8 (echo request) = Ping packets. Type 13 (timestamp request) = Used to obtain system time from the target host. Type 15 (information request) = Rarely used, intended to support self-configuring systems to allow then to discover their network addresses. Type 17 (subnet address mask request) = Reveals the subnet mask used by the target host, used when mapping networks	
B1) ICMP Probing tools	Sing (works like Ping but with enhancements as you can send diff types of ICMP). Works like "sing -echo" "sing -tstamp" "sing -mask". nmap -sP. ICMPscan, can do all of the ICMP types with flags -T (timestamp) -N (Netmask) -I (info) -E (echo)
B1) ICMP OS Fingerprinting	

	Ofir Arkin's Xprobe2 utility performs OS fingerprinting by primarily analyzing responses to ICMP probes
B1) Microsoft PPTP	1. The Point-to-Point Tunneling Protocol (PPTP) is an obsolete method for implementing virtual private networks. A PPTP tunnel is started by communication to the peer on TCP port 1723. This TCP connection is then used to initiate and manage a GRE tunnel to the same peer. Generic Routing Encapsulation (GRE) is a tunneling protocol developed by Cisco Systems that can encapsulate a wide variety of network layer protocols inside virtual point-to-point links or point-to-multipoint links over an Internet Protocol network. Microsoft PPTP uses TCP port 1723 to negotiate and establish connection and IP protocol 47 (GRE) for data communi-

	cation. 2. Uses MS-CHAP for authentication which PPTPv1 and PPTPv2 and vulnerable to bruteforce attacks.
B2) Cat 5/Fibre	Coaxial/Cat 5/Fiber Optics is pyhsical part of the physical layer. Coax cable is an older technology used in connecting networks. Cat 5 is made from copper and is twister pairs.
B2) Cat 5 Characteristics	1) Performance up to 100MHz 2) Suitable for 10BASE-T, 100BASE-TX (Fast Ethernet), 1000BASE-T (Gigabit Ethernet). 3) Category 5 enhanced (Cat 5e) supersedes Cat 5. Category 6 cable (Cat 6) is a cable standard for Gigabit Ethernet. 4) Normally use RJ45 connectors.
B2) What are 10/100/1000baseT (Ethernet)	1) They are standards that carry traffic on physical layers.
	T characteristics - 1) Also known as ethernet over twisted pair or IEEE

B2) 10base	802.3i 2)10base-T transmits at speed of 10Mbit/s using baseband transmission using twisted pair cables
B2) 100base	TX characteristics - 1) 100base-TX (IEEE 802.3u) is most common of the Fast Ethernet standard. Fast Ethernet covers copper (100base-TX, 100base-T4, 100base-T2) and fibre-optic (100base-FX,
100base	SX, 100base-BX, 100base-LX10) technologies.
B2) 1000base	T characteristics - 1000base-T (IEEE 802.3ab) is a standard for gigabit Ethernet over copper wiring.
B2) Token Ring. Where? How fast? Describe? Cabling?	

1) LAN technology which resides in the Data Link Layer (DLL) of the OSI, similar to ethernet. 2) Token Ring Network operates at 4mbps and 16mbps. 16mbps Token Ring a.k.a. Fast Token Ring. 3) Token is passed along the cyclic network. No collision. Each node has timeslice to perform processing. Special token frame circles the network when no station transmitting. Station converts token into data frame for transmission. Token Priority has 8 levels to assign to stations. Token Ring standardised with IEEE 802.5. 4) Token Ring cabling uses IBM "Type-1" shielded twisted pair with unique genderless connector (a.k.a. Boy George connector)

B2) What is a WLAN? What OSI layer?

1) A wireless local area network (WLAN) links two or more devices using some wireless distribution method (typically spread-spectrum or OFDM radio). WLAN usually provides a connection through an access point to the wider Internet. 2) WLAN is a data link layer protocol. WIFI Data Link similar to ethernet. Uses radio spectrum (shared like a hub). Usually has link layer Encryption with Authentication protocol.	
B2) 802.11 standards (4)	1) 802.11a = 50mb/s 5GHz 2) 802.11b = 11mb/s 2.4GHz 3) 802.11g = 50mb/s 2.4GHz 4) 802.11n = MIMO (multiple in multiple out)
B2) Other data link technologies? (5)	Direct connection (invisible), Serial Protocol (RS-232), Point-to-point (PPP), Asymmetric Digital Subscriber

	Line (ASDL), High-Level Data Link Control (HDLC)
B2) Bridges	Bridge connects two networks together. Operates on Data Link Layer (over ethernet). Bridge learns who is on what segment. Stores MAC addresses. Repeater sends data on without interpreting it
B2) Hubs (3)	1) Hubs are a form of repeater for an Ethernet LAN, which has multiple ports. (Sometimes known as "multi-port repeaters" or "active star networks"). 2) A hub is a shared network device. When sniffing a hub, can see all traffic. 4) A hub duplicates data packets received on one port, making it available to all other ports. Allows data sharing between all devices connected to the hub.
B2) Switches (6)	

1) Switch is like a device with multiple bridges. 2) Unlike a standard hub, a switch keeps a record of the MAC addresses of the devices attached to it. 3) When a switch receives a data packet, it forwards the packet directly to the recipient device by looking up the MAC address. 4) Switch is a network device does packet inspection and identifies where to send data. 5) Switch ports are segmented from each other. Switch ports can run at different speeds. 6) When sniffing a switch, can only see broadcast traffic.

1) Different forged source MAC addresses can be set on devices connecting to a switch. 2) The Content Addressable Memory Table (CAM) stores the MAC address to Physical Port translations. When CAM fills up, it causes a memory overflow / timeout.

B2) MAC Flooding Switches	Overflow forces switch to fallback into broadcast/hub mode. 3) Early switches with limited memory had this issue. Restarting switch is a temporal measure to reset the state. 4) Fixes include: Limit MAC addresses on each port; Rate Limit to 10 requests/second; More memory in switch.
B2) VLAN (7)	1) Virtual Local Area Network (VLAN) is a concept of partitioning aphysical network so that distinct broadcast domains are created. 2) Achieved on switches and routers. 3) VLANs splits ethernet up. Can assign different ports to different networks. 4) Using a switch for different segments on network and handling firewalls and segregation of routers and protected systems is not a certified solution. 5) For traffic to be sent to specific VLANs, packets are tagged with 802.1Q tag.

	6) VLANs are local to switch's database and VLAN information not passed between switches. 7) Do not use VLANs with Wireless
B2) VLAN Trunking (4)	1) Trunking provides VLAN identification for frames travelling between switches. 2) Trunk port allows traffic from any VLAN to through the switch. 3) Trunk port uses 802.1Q tagging. Tagged for backward compatbility. 4) Trunking must be configured on both ends of the link.
B2) VLAN Security Implications	

As an example of a double tagging attack, consider a secure web server on a VLAN called VLAN1. Hosts on VLAN1 are allowed access to the web server; hosts from outside the VLAN are blocked by layer 3 filters. An attacking host on a separate VLAN, called VLAN2, creates a specially formed packet to attack the web server. It places a header tagging the packet as belonging to VLAN2 on top of another header tagging the packet as belonging to VLAN1. When the packet is sent, the switch on VLAN2 sees the VLAN2 header and removes it, and forwards the packet. The VLAN2 switch expects that the packet will be treated as a standard TCP packet by the switch on VLAN1. However, when the packet reaches VLAN1, the switch sees a tag indicating that the packet is part of

VLAN1, and so bypasses the layer 3 handling, treating it as a layer 2 packet on the same logical VLAN. The packet thus arrives at the target server as though it was sent from another host on VLAN1, ignoring any layer 3 filtering that might be in place.	
B2) Switched Security Implications (5)	SNMP weak password. Switch misconfiguration. VLAN Hopping vulnerability. No logging. No stateful inspection. Mitigated with firewalls
B2) Baseband vs Broadband	Both baseband and broadband describe how data is transmitted between two nodes. Baseband technology transmits a single data signal/stream/channel at a time while broadband technology transmits multiple data signals/streams/channels simultaneously at the same time.

B4) Tool for seeing what is present? (6)	Ping, nmap -sP, arp-scan, icmpscan, sing, fping
B4) Tool for DNS hostnames (4 + 1)	dig, host, nslookup, ldapsearch. resolve adresses to names
B4) Tool for NetBIOS hostnames (3 +2)	nbtscan, nbtstat, lservers. Obtain names from IP addresses. Uses Name Service UDP/137
B4) Tool for OS fingerprinting (5)	nmap -A, xprobe2, ARP, ICMP echo reply TTL can indicate OS, port scans can reveal OS specific host
B4) Tool for services/ports (2)	nmap -sS, -nmap -sU
B4) Tool for application fingerprinting (2)	telnet, openssl
B4) Tool for network sniffing (2)	Wireshark, TCPDump
B4) Tool for route (2)	Tracert / traceroute, ping -r
B4) Windows and Linux only ports (5 + 1)	TCP/135, UDP/137, UDP/138, TCP/139, TCP/445 . Linux (TCP/111)
B4) nmap scan types (6)	

Full/Vanilla Connect (-sT), Xmas (-sX), FIN (-sF), NULL (-sN), SYN/Stealth/Halfway (-sS), ACK Flag probing (-sA/-sW)	
B4) High priority targets vs low priority	High Priority: Servers and AD (Active Directory), Firewalls, Routers, etc. Less Priority: Printers and Workstations. If only conducting a sample, try and have diversity of systems types to test.
B4) Stealth Scanning Technique (Inverse TCP Flag)	Inverse TCP flag scanning = send with another flag (not SYN) knowing that only closed ports will respond. Flags include FIN, XMAS and NULL. Getting no response is open, getting RST/ACK is closed. Effective against Unix but not Windows
	Identify open TCP ports by sending ACK probe packets and analyzing the header information of the RST packets received from the target host. Analysis

B4) Stealth Scanning Technique (ACK Flag probing)	of the time-to-live (TTL) field of received packets or Analysis of the WINDOW field of received packets.
B5) Arp Scanning Characteristics	Scan a network to find active hosts. Limitation: Only works on a local network. No routable. Very fast, simple protocol. Does not use TCP and can scan a class B network. Very reliable. Never blocked. Not possible for firewall to block unless it is host-based firewall. Disadvantage: IP requires ARP.
B5) Arp Scan tools	arp-scan runs on Unix/Linux. Not available for Windows because of pcap. arp-scan works on Ethernet and Wifi.
B5) Ping sweep tools	fping is more flexible/presentable than ping. icmp-scan. nmap -sP
B5) TCP Connection to Filtered Port?	

	SYN packet doesn't get any response. This is different to Closed which is when it gets a RST back
B5) UDP Scanning via ICMP	Can be done with ICMP packets as if it sends back ICMP Unreachable/Port unreachable if it is open. No response sent if it is not listening. Can get false positives
B5) Network sniffing of broadcast protocols? (1+ 4)	If plugged into a switched network you'll only be able to see the broadcast traffic. Spanning Tree Protocol (STP) is a regular protocol. Cisco Discovery Protocol (CDP) is a broadcast protocol. Only used by Cisco devices. ARP Requests will tell you potential IP addresses. Map IP address and MAC address. NetBIOS runs on Windows only, normally giving some information like system name and IP address.
B6) How to evade firewalls? (4)	

Source Porting, Fragmentation, Ingress and Egress filtering, Out-bound connect risks (Data export and reverse shell, even through closed ports)	
B6) What is spoofing? (3)	1) Spoofing is where the source address is forged. 2) can occur on most OSI layers. 3) Spoofing attacks are blind. If source address is forged, the attacker will not receive any data back.
B6) Spoofing on each layer (2,3,4 and 7)?	Ethernet (Layer 2: DL). Able to set any source address, e.g. MAC address. Not a bug. IP (Layer 3: Network). Able to set any destination address. UDP/ICMP (Layer 4: Transport). Able to set source address. Cannot trust source address as transport is connectionless. TCP (Layer 4: Transport). If the TCP sequence numbering is pre-

	dictable, then it is spoofable. SMTP (Layer 7: App).
B6) How to prevent spoofing? (3)	1) Not trusting the source address. 2) Sign with PGP. For example, with SMTP, anyobdy can send on someone's behalf and forge an email address. With PGP, the message is signed with a signature. 3). Fix TCP sequence number such that it is random. Do not allow to trace.
B6) How can you bypass a firewall with Filtering?	For example, Firewalls set for internal network, allow DNS/NTP to go outbound. WWW server may have some data, e.g. NTP to synchronise the time or SMTP to handle mail. Attacker can set a reverse shell, cmd.exe
	Limit traffic by applications. Based on application level details. 1) SMTP Mail Addresses (MAIL TO / RCPT FROM) 2) Web URLs (Blacklist of disallowed

B6) What is content filtering? (1 + 4 examples)	URLs/whitelist of allowed URLs) 3) FTP Filenames 4) Stateful Inspection at firewall
B6) How do you achieve content filtering and what are the protocols used? (2)	1) Content filtering using a proxy with an application level gateway 2) On PIX Firewall, PIX defines the content filtering protocol as FIXUP. On Checkpoint Firewalll, Checkpoint defines the content filtering protocol as RESOURCE. Some fixup/resource are on by default (e.g. DNS/SMTP)
B8) NTP OS Fingerprint (How and what port)	NTP (Network Time Protocol) services listen on UDP port 123 and can be queried to obtain remote hostname, NTP daemon version and OS platform details
B8) OS Fingerprinting Options (4)	

1) ARP fingerprinting' is restrictive to local LANs. Tool: arp-fingerprinting (arp-scan). 2) Assess 'Ping TTL'. When doing a ping sweep TTL will return different values. TTL=255 for Cisco and Linux. TTL=128 for most identifible OS. Usually Windows. e.g. TTL of 123 is also Windows. TTL=64 for Linux. 3) Assess available 'Network Services'. If ports 135, 137, 139 and 445 are open, it is a Windows system. If port 111 is open, it is probably a Solaris/Unix system. 4) TCP/IP Stack Fingerprinting. If TCP/21 is closed and TCP/22 is open, then it is possible to find out operating system.Tool: nmap -O -P0 -n -v -P 21,22 host

B8) TTL for OS's? (3)

Assess 'Ping TTL'. When doing a ping sweep TTL will return different values. TTL=255 for Cisco and Linux. TTL=128 for most identifible OS. Usually Win-

	dows. e.g. TTL of 123 is also Windows. TTL=64 for Linux. Solaris TTL=256
B8) Application Fingerprinting Techniques (5)	1) Banner Analysis 2) Probing ports 3) Manual. e.g. telnet and "GET / HTTP/1.0" 4) Automated. e.g. amap 45)HTML Data Inspection (distinct links, files/folder presence)
B8) Passive fingerprinting techniques (definition + 2)	No traffic generation. Send, receive or sniff data.Tool: p0f
B9) Application Fingerprinting Options (3)	SMTP, Finger, Telnet
B9) Evaluation of responsive but unknown network applications (3)	Time protocol, ping or fping if there are lots to test. traceroute (tracert and similar with ping -r)
B9) SMTP for application fingerprinting?	

TCP/25. RFC 821 (b.1982). Plain Text Protocol. No authentication. Information Leakage (Vulnerability): 1)Different responses to particular commands. RCPT TO: if recipient is OK, it responds with a status of 250 2.1.5. If not found, it responds with error/blank. 2) VRFY verifies address. If it works, it is a bug. 3) EXPN expands address. If it works, it is a bug. Implementation: Mail server used to run under root/administrator. Hence possible to bring up root shell (untrusted). Sendmail has no authentication.

1) TCP/79. RFC 742 (1979). Plain Text Protocol. No authentication. Used to find out user status and information. AKA Name/Finger protocol. Name and finger programs that provide status reports on a particular computer system or a particular per-

B9) Finger for application fingerprinting (Description and Vulnerabilities)	son at network sites. Default on Solaris installation. (Finger Protocol, Finger Client program, Finger Server program.) Daemon is fingerd or in.fingerd (for Internet). 2) Vulnerabilities Information Leakage, Daemon implementation issues.
B9) Telnet for application fingerprinting (5)	TCP/23. RFC 854. Plain Text Protocol. Used for remote login. Used to connect to Linux/Unix systems or Network devices (e.g. Cisco Routers), still seen in the latter. SSH is the secure replacement.
B9) Time protocol for unknown host	TCP/37, UDP/37. RFC 868. Binary protocol. Returns a 32-bit value. In seconds since 1st January 1970. Network Byte Order — big endian.
B9) Ping	

r vs Traceroute (6) - 1) Ping limitation is that is only 9 slots for the IP header and only records up 9 entries at a time vs 30 in traceroute. 2) traceourite is one-way directional, ping is not as it will reply. 3) Ping can completely map a network (so better to use on an internal network). 4) Traceroute not a protocol but a tool 5) Traceroute is more flexible and can work even if the host is unreachable 6) with traceroute, if a host is listening on a port it will not get back ICMP, it will keep listening and return ***

B9) What is RPC?

Remote Procedure Call is a technique for building distributed systems. Basically, it allows a program on one machine to call a subroutine on another machine without knowing that it is remote. RPC is not a transport protocol: rather, it is a method of using existing

	communications features in a transparent way.
B9) Linux vs Windows RPC	1) ONC/RPC (Open Network Computing RPC) is primarily used in Linux/Unix. vs DCE/RPC (Distributed Computing Environment RPC) is primarily used in Windows. 2) Unix Portmapper is on TCP/111 and UDP/111 vs Windows Portmapper is on TCP/135. (Also uses 136 — 139)
B10) What is the point of filtering and firewalling?	Without it you could conenct to any address on any port. Filtering limits IP traffic (usually on Layer 3 and 4)
B10) How does IP filtering work?	Filtering limits IP traffic (usually on layer 3 and 4). Filtering by source and destination IP address (Network Layer). Filtering by destination port (Transport Layer). Filtering by protocol (Network Layer).
B10) Host based firewall? (3)	

1) Host-based firewall is where the host protects itself only. Host-based firewall is useful for second-line defense. Windows Firewall is an example of a host-based system. 2) Most have static filtering. 3) Windows Firewall has IP Filtering (which is static). Linux Firewall uses IP tables (which is dynamic).

B10) IPsec? (3)

1) Internet Protocol Security is a secure network protocol suite that authenticates and encrypts the packets of data to provide secure encrypted communication between two computers over an Internet Protocol network. It is used in virtual private networks. 2) IPSec contains IP filtering. It can drop, allow in the clear, allow encrypted traffic. 3) IPSec uses a policy database. It has better control than Windows.

B10) Stateful packet inspection?

Also known as Dynamic Packet Filtering, it aims to monitor active connections on a network. They keep track of each connection and constantly check if they are valid, which is why it offers a better protection than static packet filtering. Static only checks the headers of the packet in order to determine whether they should be allowed through a firewall. Can open up a dynamic rule for 60 seconds etc	
B10) Static filtering syntax (2)	For TCP, format: ALLOW tcp src dest port. ALLOW tcp ANY 192.193.194.195 eq 25 (syn all - allows all traffic in). eq means equal to.2) For UDP: ALLOW udp 192.193.194.0 ANY eq 53. ALLOW udp ANY 192.193.194.0 gt 1023. Problem DNS server sends data back on port about 1023. Rule should allow any UDP port above 1023.
B10) TCP Wrapper	

1)TCP wrapper is a host-based Networking ACL system, used to filter network access to Internet only seen in Unix/Linux. It is implemented at application layer, not in kernel. 2) They control access to network services via inetd command followed by the service name. 3) access is controlled by 2 files /etc/hosts.allow and /etc/host.deny

B10) Clean up rule

Rule 20 shows the cleanup rule. Usually this is the last rule as a catch all for any items that are not covered by rulebase. Ideally there should be a cleanup rule due to the unpredictable nature of default cleanup action of each firewall: 20 ANY ANY ANY DROP YES (No SRC DST SERVICE ACTION LOG)

B10) Firewall/NAC logging best practices (3)

1) Everything should be logged. (see rule 9). Except for 'noisy' protocols that broadcast every second. This will fill up log quickly. (see rule 10). 2) Every ACCEPT must be logged. DENY should be logged, i.e. the cleanup rule. (see rule 20). 3) If not logged there is no audit trail. Firewall is the only log trusted, for example, a HTTP log can be modified if compromised. Firewall cannot.	
B11) Encryption vs Encoding	1) Encoding is not really encryption, it is converting data by use of a code. Encryption is the process of changing plaintext into ciphertext using a cryptographic algorith and key. Ciphertext should be indistinguishable from random data.
	Symmetric = Secret Key (Same key used to decrypt/encrypt) vs Asym-

B11) Symmetric vs Asymmetric Encryption	metric = Private/Public Key (Encrypt with one / Decrypt with another). Key Length for symmetric is 56-256 bits vs Key Length for asymmetric is 512-4096 bits
B11) Symmetric vs Asymmetric Example Ciphers	Symmetric = DES, 3DES, AES, RC4 vs Asymmetric = RSA
B11) What is a cipher?	Cipher is encrypted text. P ---E---> C {encyption}. C ---D---> P {decryption}. Without E (Encryption), it is difficult to workout C (Cipher). Stream Cipher e.g. RC4
B11) Stream Cipher vs Block Cipher	The main difference between Block cipher and Stream cipher is that block cipher converts Converts the plain text into cipher text by taking plain text's block at a time. While stream cipher Converts the plain text into cipher text by taking 1 byte of plain text at a time
B11) Windows Password Hashes (2)	

1) LANMAN Hash. Used in older versions of Windows. Uses sets of 7 characters and is UPPERCASE only 2) NTLM. NT LANMAN Hash uses unsalted MD4 hash, is mixed case and is not split up into groups of 7 characters.	
B11) What is Cisco Type 7	Cisco Type 7 is a weak fixed key. It is easily reversible. It uses the vigenere cipher. A strong cipher in the 16th century.
B11) HMAC?	Message Authentication Codes. Designed to stop interference with encrypted messages in transit. Normally built in to the cipher appended to every message, using a secret key to generate a hash of the message that comes before it
	1) Authentication: One-time Passwords and Certificates. 2) Encryption: Ciphertext unreadable to those with-

B12) Uses of cryptography? (3)	out keys. 3) Integrity Checking: Protects against noise/malicious tampering. Hash and Message Authentication Code (MAC).
B12) SSL/TLS version flaws	SSLv2 was a proprietary version formed in 1994. SSLv2 has known security vulnerabilities.
B12) SSL server vs client auth?	SSL always performs server authentication but rarely performs client authentication. This is done using a certificate. C ——>[S] — Server has to verify to client that it is who it says it. Server must have a certificate
B12) Weak ciphersuites	RC2, DES, NULL
B12) SecurID	6-digit value that changes every 60 seconds and is based on clock synchronisation. It is two-factor authentication where a 4-digit PIN is entered, followed by the key fob value. Server has serial # of the client.

	Hence it requires, a PIN, token value and some details about the client. It doesn't eliminate MitM.
B12) What is IPSec?	A suite of protocols. Internet Key Exchange (IKE) runs over UDP/500. Encapsulating Security Payload (ESP) uses IP/50. Authentication Header (AH) uses IP/51. IPSec is a network layer (layer 3) protocol. App: SMTP, Tra: TCP, Net: IPSEC/IP, DL: Ethernet, Phy: (Cable)
B12) PGP	PGP is a data encryption and decryption computer program that provides cryptographic privacy and authentication. PGP often used for signing, encrypting and decrypting texts, e-mails, files, directories and whole disk partitions to increase the security of e-mail communications.
B12) Wireless Encryption Importance	

Wireless should have encryption. Very easy to sniff over the air. The wireless signal has a range. Wireless standard is 802.11.

B12) WEP

Wireless Equivalent Privacy (WEP)
WEP (Wireless Equivalent Privacy) introduced in 1997. For encryption used RC4 (Stream Cipher). RC4 encryption should not reuse the key as XOR the key itself gives the cipher text. WEP has two methods of authentication: 'Shared' and 'Open System': 'Open System' does not require authentication per se. The keys must be right to encrypt data frames. 'Shared' uses a configure WEP key to encrypt a challenge back to the server. At least WEP is better than no encryption

B12) TKIP

	Temporal Key Integrity Protection (TKIP) . TKIP uses RC4 (128-bit) and this is used in most wireless hardware
B12) WPA	Wi-Fi Protected Access (WPA). WPA-TKIP has weakness that allows attackers to decrypt data packets for a keystream
B13) What is the Unix security model?	Everything is a file. e.g. files, devices, etc. File protection is the key security point. /dev is a device. /proc is a file with system config/process. 2 classes of users: 'users' and superuser'. All users have an ID, 'uid'. 'Users' have uid!=0. Superuser have uid=0. 'root' is default superuser and convention. 'root' can be renamed but causes problems. 'root' has control of most of the OS. Look to root' a system
B13) Unix File Protection	

Every file has meta-data associated. Meta data is admin-useful data. A file has an 'OWNER', a 'GROUP' and a 'MODE'. The 3 bits represents permissions. For normal files, bit 0 represents execute', bit 1 represents 'write' and bit 2 reprsents 'read'. For special permissions, bit 0 represents the 'sticky bit', bit 1 represents 'SGID' and bit 2 represents 'SUID'. SUID can set UID/GUID.	
B13) File vs Directory UNIX perms	File = R | Read Data, W | Write Data, X | Execute Program. Directory = R | List Contents (ls), W | Add, Delete, Rename Files in directory, X | Traverse Directory
B13) Normal UNIX permissions for files, programs and directories?	Text Files usually have permissions of 640. Programs usually have permissions of 750. Directories usually have permissions of 755
B13) CRON	

CRON runs scheduled tasks. CRON is a program that runs every minute. Configuration files are stored in a CRONTAB.	
B13) Linux Priv Esc (3)	1. Writable SUID executable files. (e.g. root 4777). Note: Writing to the file drops the setuid bit in most OS. 2. Writable files that are executed/processed by root. (e.g. crontab) 3. Files in a writable directory executed by root. (e.g. can change files in a writable directory).
B13) Privileges when creating files	1) Programs can control permissions set when files are created while running program. e.g. 0666 and 0777. 2) umask can be set at the system login and in the user profile. Unix uses umask as a template on what default permissions a file should have. Windows uses inheritance. umask set to

	0002 prevents world-write access to the file.3) 000 => No restriction 777 => No access
B14) Listing processes on Unix (4)	1)ps, PID, process ID is a number. PPID, parent PID. 'Terminal' column can be any device. 2) "pstree" lists process as a tree. 3) "top" — gives the memory dump in memory. 4) "lsof" — lists open files
B14) What does netstat do?	Displays network sockets (listener/active). netstat works on Linux, Solaris and Windows. Interested in TCP Sockets and UDP Sockets. UNIX domain sockets are also displayed.
B14) netstat flags (6)	> netstat # works in Windows as well as Unix/Linux. > netstat -a # displays all sockets. > netstat -n # do not resolve ports to names. $ netstat -t # TCP only (Linux). $ netstat -u # UDP only

	(Linux). $ netstat -p # Shows owner of process (Must be root in Linux)
B14) Listing processes in Windows (4)	1) Process tab in task manager — This is GUI-based and not good for getting process list. 2) tlist.exe — part of the resource tool kit (on older Windows OS) 3) tasklist.exe — works on XP (not XP Home) and onwards and onboard most operating systems. 4 Sysinternals tools, e.g. procmon, sysmon and pstat
B14) Windows, Solaris and Linux patches?	Solaris/Windows use patch updates. Linux use updated packages
B14) How to assess patches on Unix? (5)	For a good patch assessment, check the following: 1) Installed patches (e.g. showrev). 2) Full list of (manufacturer released) available patches. 3) Installed components. 4) OS Version (e.g. uname). 5) Architecture (e.g. uname).
B14) How to assess patches on So-	

1) Installed patches (showrev), 2) Check pathdiag.xref for all available patches for all systems back to 1990 (found and stored in /var/tmp). 3) Can use Patch Check Advanced (pca) to assess. This will show 2 numbers. First number is the number of patches missing. Second number is the total number of days out of date.

B14) How to assess patches on Windows? (3)	1) wmic qfe (works on windows XP and above) 2) Released patches can be found in Security Patch Bulletin Catalog (mssecure.xml/mssecure 1.cab) or in Microsoft Security Bulletins page. 3) Tools like: hfnetchk, hfnetchkpro, MBSA, Nessus, Languard
B14) Forensics plan for finding interesting files	

For forsenics, create a copy. However must ensure nothing is changed on master (primarily anything effects last action date). Mount drive as read-only. You may need to generate hash of drive. Having a write-blocker device can be used to make a copy. Police and Criminial Evidence (PACE) act guidelines recommend that volatile data is captured before system is powered down (as shut-down processes saves data and closes files)

B14) Find interesting files on Linux?	find command will locate diles on a Linux/Unix system by their date, size, name, owner/group, mode. filetype. find
	$ find / -name x.txt # Look for x.txt on the system. $ find / -name *.txt # WRONG! * expands out and find

B14) Find command syntax	doesn't work as expected. $ find / -name '*.txt' # CORRECT! This finds all text files. $ find / -name "*.txt" # CORRECT! $ find / -name *.txt # CORRECT!
B14) Find command for files with special permissions in Unix/Solaris vs Linux	1) Unix/Solaris = $ find / -perm -4000 # finds all setuid files (directory/links). $ find / -perm -0002 # finds all world writable files (usually tempfiles). $ find / -perm -002 -type f # finds all world writable files only. $ find / -perm -002 -type d # finds all world writable directories only. $ find / -mode -4000 # finds all SUID files $ find / -mode -2000 # finds all GID files. 2) Linux = $ find / -perm +4000 # finds all setuid files (directory/links). $ find / -perm /4000 # finds all setuid files (directory/links). This is a new format. $ find / -mode +4000 # finds all SUID files. $ find / -mode +2000 # finds all GID files

B14) Interesting directories on unix	/tmp # Store temporary files like SSH Key files. Cleared out regularly. /var/tmp # Not cleared out so often.
B14) Linux/Unix commands for finding info about a file (7)	cd, ls, stat (Only in Linux, tells information about the file and metadata), lsof (list of open files), less/more/cat/tail/head show the file contents, df (shows partitions mounted), od (takes a binary file and looks at the contents)
B14) Finding files in Windows	Use "dir /s name*.*" to search for files. Use Windows explorer search facility to search files.
B14) Finding information about Windows file objects	> cacls . > xcacls # Found in Windows Resource Kit. > icacls # Vista
C1) WHOIS ()	It is actually a protocol in itself that runs on TCP/43.2) Often only seen as a web service where you can do scans do get registrant information, but can

	be a UNIX command too. 3) WHOIS server limits number of requests.
C2) What does the DNS protocol do + port?	Maps names to IP addresses (vice versa). DNS uses UDP/53 and TCP/53.
C2) What is the hosts file in DNS?	Host files used to manually set a name to an IP address. Linux/Unix: /etc/hosts. Windows: %SYSTEMROOT%\System32\drivers\etc\hosts. Hosts file represents attack vector for malicious software
C2) Why was DNS created?	Host files were all that was used before, but had the following issues and so DNS was created to mitigate: Scaling problems: Coordination (between all users to avoid conflicts), Inconsistencies (between up-date/distribution of new version), Reliability (single point of failure), Performance (competition for centralised resources)
C2) DNS Root Zone?	

Its the highest level of the DNS name, above .org, .com etc. Root contains 13 server clusters that are authoritative for queries to the global DNS root zone. Root servers have official names, a.root-servers.net to m.root-servers.net

C2) DNS TLD?	Top Level Domain (TLD) is the first level of names (e.g. com, net, etc). .com will delegate a group of nameservers to apple. (e.g. www.apple.com)
C2) DNS Resolver vs Server?	DNS server is a name server that provides resolution of human-memorable domain names and host-names into corresponding IP addresses. DNS resolver is for the client-side. Responsible for initiating/sequencing queries to DNS server for full resolution of given resource. DNS resolver talks to DNS Server which provide full

	translation of domain name and Internet name to IP address. When DNS resolver requires a name, it needs DNS server to resolves an IP address to a name. DNS resolver built into a system. It is a library.
C2) DNS Server	Usually primary and secondary DNS server assigned when your computer requests network information via DHCP. If DNS server is suspected not to be working or not assigned, then can use public DNS servers.
C2) DNS resolution example	

DNS resolver asks for www.apple.com. (Assume www.apple.com is not in client local cache). DNS client sends query to preferred DNS name server. DNS name server checks to see if can answer query authoritatively based on RR information in locally configured zone. DNS name server checks to see if name can be resolved from locally cached information. If DNS name server fails to resolve query, server uses recursion with other DNS servers. List of IP addresses considered authoritative at the root level (root name server). This is the root hints file. Preferred name server determines a root server to contact, which determines a name server authoritative for TLD, "com". Preferred name server will contact "com" name server with an iterative query

to obtain referral to "apple.com". Preferred name server will contact "apple.com" name server with an iterative query to obtain referral to "www.apple.com

C2) Recurisve vs Iterative DNS queries

Recursive DNS queries occur when a DNS client requests information from a DNS server that is set to query subsequent DNS servers until a definitive answer is returned to the client. The queries made to subsequent DNS servers from the first DNS server are iterative queries. Iterative DNS queries are ones in which a DNS server is queried and returns an answer without querying other DNS servers, even if it cannot provide a definitive answer. Iterative queries are also called non-recursive queries. A recursive query is a request from a host to a resolver to find data on oth-

	er name servers. Recursive query is served by resolver. A request, usually made by a resolver, for any information
C2) What is a DNS Zone Transfer	DNS zone transfer, also known as DNS query type AXFR, is a process by which a DNS server passes a copy of part of its database to another DNS server. The portion of the database that is replicated is known as a zone. A zone transfer uses the Transmission Control Protocol (TCP) and takes the form of a client-server transaction. The client requesting a zone transfer may be a slave server or secondary server, requesting data from a master server or a primary server.
C2) DNS Zone Transfer Tools?	

For all these tools, you first need to find out the nameserver that is being used. After this you can run these tools on them. dig axfr (dig axfr @. dig axfr @10.0.0.1 example.com), host -t axfr (host -t axfr example.com nameserver) , nslookup (nslookup using non-interactive mode: nslookup -q=axfr google.co.uk — 8.8.8.8. nslookup using interactive mode: $ nslookup - nameserver | > set q=axfr | > training.com	
C2) Structure of DNS?	When DNS asks a resolver for a name, it will return a Resource Record (RR). Resource Record (RR) is data element in DNS. RR have a defined format: Owner, Time To Live (TTL), Class, Type, Record-specific.
C2) DNS Record Types A	Address Record. IPv4 address of a particular host (32-bit).
C2) DNS Record Types AAAA	

IPv6 Address Record. IPv6 address of a particular host (128-bit)	
C2) DNS Record Types CNAME	Canonical Name Record. An alias for the real name of the host.
C2) DNS Record Types MX	Mail Exchange Record. Maps a domain name to a list of message transfer agents (MTA).
C2) DNS Record Types NS	Name Server Record. Delegates a DNS zone/subtree to given authoritative name server
C2) DNS Record Types PTR	Pointer Record. Pointer to a CNAME. Used for Reverse DNS lookup as maps IP address to hostname. PTR record uses .arpa format for IP address.
C2) DNS Record Types SOA	Start of Authority Record. Admin record. Specifies authoritative information about DNS and denotes the start of a DNS zone/sub-tree. SOA information includes primary name

	server, email address of domain administrator, domain serial number, timers relating to refresh.
C2) DNS Record Types TXT	Text Record. Originally arbitrary human-readable text but record carries machine-readable data, such as RFC1464. TXT record can relate to: Opportunistic Encryption (OE), Sender Policy Framework (SPF), Domain Keys Identified Mail (DKIM), Domain-based Message Authentication, Reporting and Conformance (DMARC), DNS based Service Discovery (DNS-SD)
C2) DNS Record Types AXFR	Authoritative Zone Transfer. Transfer entire zone file from the master name server to secondary name servers. IXFR = Incremental Zone Transfer. Requests a zone transfer of the given

	zone but only differences from a previous serial number.
C2) DNS Record Types HINFO	Hinfo Record. Host type and operating system information.
C2) DNS Vulnerabilities	1) Incorrect Admin Information. 2) Zone transfer. 3) Version information (Information leakage on finding out version of BIND. Query the Version.bin TXT record for the CHAOS class. CHAOS TXT Version.bind). 4) Cache poisioning, problem is DNS does not have authentication or encryption. Solution is to use DNSSEC. DNSSEC is the standard but not seen in infrastructure. 5. BIND vulnerabilities, should know the major ones for V4 & V8. Problem if reachable from Internet
C3) How to get webapp info from HTML content etc (5)	

1) Look for known files on target web site (e.g. /robots.txt). 2) Look for server information leaked in http response banner. Look for application version in displayed content. 3) Look for names, phone numbers, email addresses, internal IP addresses in displayed content/within HTML source. 4) Look for comments/metadata within HTML source. 5) Look for error pages.

C4) Google hacking operators

1)filetype:doc (ext:doc) searches for specific doc filetype 2) site:domain.com searches only for specific site or domain. 3) cache:domain.com searches google's cached version of a web page. 4) intext:word searches for pages with terms that appear in text of page 5) allintext:word searches for pages with all the terms that appear in

	text of page. 6) inanchor, allinanchor, intitle, allintitle, inurl, allinurl.
C5) NNTP Newsgroups Recon	1) " site:groups.google.com" search for news articles with that . 2) Other search engines designed for news articles from different sites (e.g. newslookup.com) 3) Search for mailing list (e.g. lsoft.com) 4) Search engine designed for forum entries (e.g. omgili.com)
C6) Email analysis	1) Note the Sender: of the email is not the same as From: This is an administrative assistant. 2) Received: and Return-Path headers contain trace fields and leak information.
D1) Weaknesses in Telnet	Passes authentication details in the clear (look for 'User Access Verification Password' response), bruteforce, 'show ver' and 'show run' will display

	current configuration once authenticated, default passwords
D1) Weaknesses in Web based protocols	Connect to the management interface, HTTP is in the clear, username and password guessing, web applicarion vulnerabilities, default creds, old router bug that shows config (http://router/level/99/exec/showconfig)
D1) SSH weaknesses	Identify version in banner, look for 'User Access Verification Password' response), bruteforce, 'show ver' and 'show run' will display current configuration once authenticated, default passwords
	runs on UDP/161, still widely used, SNMPv1 has no ecnryption, SNMPv1 uses community name as password authentication and no username is required, the SNMP MIB (Managed

D1) SNMPv1 and 2c weaknesses	Information Base) data can be retrieved from a device by specifying the correct read community string. Enumerate Usernames of Active Accounts in Windows: snmpwalk -c public 192.168.51.29 .1.3.6.1.4.1.77.1.2.25
D1) SNMP3 weaknesses/features	has improvements but not commonly seen, SNMPv3 has encryption with DES and AES and uses HMACs. Recommend SNMPv3 or choose a strong community string. SNMPv3 has username + password no
D1) SNMP communiction structure	client sends command to server, server responds. Commands include: GET, GET NEXT, SET. GET NEXT gets the value from a list. Management Information Base (MIB) contains SNMP structure
D1) SNMP, OID vs MIB?	

OID is object identifier. Anything and everything that can be monitored by SNMP has an OID. Let's say that you want to measure the temp of a server, this would be an OID that is a bunch of numbers separated by dots. MIB is management information base. It is a text file that allows us to translate numerical OIDs in the text-based OIDs. There are a few default OIDs/MIBs that you can query like sysuptime.0. The network monitoring device will connect to the device it wants to monitor over Port 161 and then ask for a certain OID result

D1) How do you use SNMP maliciously?

By nature this can be used to amend device config, if an attacker can read your packets and get your community string then they could take control of the device. SNMP can also be used to

	enumerate user accounts, passwords, groups, system names, devices etc.
D1) Types of SNMP community string?	1) Read only: This mode permits querying the device and reading the information, but does not permit any kind of changes to the configuration. The default community string for this mode is "public." 2) Read Write: In this mode, changes to the device are permitted; hence if one connects with this community string, we can even modify the remote device 's configurations. The default community string for this mode is "private."
D1) SNMP tools/commands	This includes 'snmpget' (get request), 'snmpset' (set request), 'snmpwalk' (get next request), 'snmptable' (get the value into a formatted table) and 'snmpnetstat' (output like netstat for-

	mat), most commonly tool used is 'snmpwalk'
D1) Cisco SNMP vulns	Upload router config over TFTP from Cisco devices using SNMP request (must have read-write access). Tools that can automate the task: Metasploit auxiliary/scanner/snmp/cisco config tftp
D1) TFTP Functionality?	Runs on UDP/69. No authentication required. No directory listing, cd or pwd. Only supports GET and PUT. Used in switchers, routers and embedded devices. Can access any file under the TFTP root directory. TFTP can be used to transfer configuration/files between routers and server along with SNMP.
D1) Cisco Reverse Telnet Functionality	

Allows you to access Cisco serial ports via TCP/IP. Listens on TCP port 2000+line number. Reverse Telnet gives you the ability to telnet to a device, and then console to another device from there. For example, you could telnet to a router, and then console into a switch, or a modem, or anything that has a console port. There are alot of devices out there that dont have remote access built into them, their only option is a console session. Well, this will allow you to remotely manage these device

D1) NTP

Network Time Protocol. Used for time synchronisation of computer clocks. Runs on UDP/123. Mutliple versions. Allows hosts to compare their CPU time clock with the server and work out their latency if any. Data messages (details of timestamps) and Control

	Messages (information about controlling and monitoring, handling the read and write of NTP variables). Access control is normally IP based.
D1) NTP Functions (4)	1) Get Time (data) uses default config and details whom it is syncing with 2) Change Time (data) could be a problem as UDP can be spoofed. 3) Read Config (control) 4) Write/Change config (control)
D1) NTP tools	1) get time: ntpdate -q ; ntptrace . 2) ntptrace tells you the hierarchy and sometimes it will fail. 3) read config: ntpq -p ; ntpq -c cmd . 4) ntpq lists the peers. 5) cmd = rv (read variables
D1) NTP to identify vendor of network device?	ntpq -c rv 10.0.0.1, ntpq -c ntpversion, ntpq -c opeers
	Network sniffing, listening passively to network traffic, useful initial step if not network information. On a switch net-

D2) Local Network Traffic Analysis techniques?	work only broadcast traffic seen. Can save network in a pcap file for later analysis
D2) Common broadcast traffic	ARP requests. NetBIOS from Windows, Spanning Tree Protocol (STP) from switches and bridges, CDP (cisco equipment)
D2) What is a pcap file?	pcap is an application programming interface (API) for capturing network traffic. Packet capture (PCAP) analysis is the process of obtaining and analyzing individual data packets that travel through your network. Because packet analysis (also known as packet capture or packet sniffing) is crucial to network management, network admins should understand the key concepts of packet capture analysis.
	How many IPs are being contacted? What User-Agents are there? What do-

D2) Things to look for during network traffic analysis?	mains are being resolved? What % of the packets are which protocol? Get rid of the stuff which looks okay and keep sifting down
D3) What is ARP and how does it work?	Address Resolution Protocol (ARP) is used to allow devices on a local network to locate the ethernet hardware address of another IP on the same local network. It works by host sending an ARP request broadcast to a network segment asking if anyone knows who owns 10.0.0.2. The host that is 10.0.0.2 will then reply saying that yes it is that and send its MAC address. It maps the IP and the MAC and stores it in cache.
D3) ARP security vulnerabilities	

1) No authentication (no control over who sends and who replies) 2) This can lead to ARP spoofing where a fake ARP message sent on a LAN associates an attackers MAC with IP of another host, causing the traffic for that IP to go to them. 3) ARP poisoning where instead of posing as another IP, it simply drops the packet. Solution is to use encryption (IPv6 doesn't use ARP it uses an alternative called Neighbour Discovery Protocol). 4) Fragmentation/Offset attacks = DoS when reassembling fragmented packets.

D3) DHCP Features

Allow systems to get an IP configuration (IP, subnet mask, gateway, domain name, dns server). Client + Server with no authentication. Was a replacement of BOOTP which used the same ports, UDP 68 and UDP 67.

	Supports dynamic addresses and provides all the necessary IP config.
D3) DHCP Vulnerabilities	Rogue DHCP server can disrupt the network by assigning wrong addresses to clients. Multiple routers offering DHCP services. 2) gain netowkr information by plugging into the network, use port authentication
D3) What is CDP?	Cisco Discovery Protocol. Cisco devices send CDP broadcasts by default. They contain lots of information about device configuration, so can be used to gather information about neighbouring network devices, determine the type of hardware or equipment, software version, active interface etc.
D3) CDP Vulnerabilities	CDPwn is a series of vulnerabilities in CDP protocol due to improper validation of CDP messages. Could be used to get RCE and DoS
D3) What is HSRP	

Hot Standby Router Protocol. Cisco proprietary redundancy protocol for establishing a fault-tolerant default gateway. A redundancy protocol exists to increase router availabiity. By sharing an IP address and a MAC (Layer 2) address, two or more routers can act as a single "virtual" router. Sort of acting like a primary/back up or load balancer for them. HSRP sends hello messages to multicast address 224.0.0.2 (v1) an 224.0.0.102 (v2) on UDP/1985. Not a routing protocol and does not advertise IP routes or affecting the route table.

D3) HSRP Vulnerabilities	Send specially crafted packets so that it thinks you are the 'Active' router and redirects traffic your way to cause MiTM or DoS
D3) What is VRRP?	

Open source redundancy protocol that increases router availability. Similarly to HSRP it operates with a primary/backup or load sharing model. VRRP uses 00-00-5E-00-01-XX as MAC address. XX is the Virtual Router IDentifier (VRID). VRRP sends hello messages to multicast address 224.0.0.18 using IP/112. VRRP not a routing protocol and does not advertises IP routes or affecting the route table.

D3) VRRP Vulnerabilities

Loki is a tool for attacking VRRP. The same vulnerabilities exist in VRRP as in HSRP with minor differences, such as denial of service (DoS), man in the middle (MITM) attack (rerouting traffic through the hacker's PC), and some information leakage.

D3) What is VTP

VLAN Trunking Protocol. Cisco proprietary protocol that switches use to exchange VLAN information. It propagates the Virtual Local Area Networks (VLAN) information (such as VLAN ID or VLAN name) on the whole LAN. Authentication is optional.	
D3) VTP Vulnerabilties	If used without authentication, inject spoofed VTP packets to change VLAN configuration. Corrupt the VTP database. DoS by triggering certain errors etc.
D3) What is STP?	Used by bridges and switches to detect and prevent loops. The spanning tree protocol (STP) was introduced into the networking world as a means to prevent layer 2 network loops (frame broadcast storms) from disrupting the service of a local area network. STP uses clever mechanisms

	to prevent loops by virtually disconnecting redundant links.
D3) STP Vulnerabilities	No authentication. Inject spoofed STP packets to disrupt network operation. Our attack vector is to disrupt the switch's spanning-trees, destabilize their MAC address-tables and hold the network in a constant state of reelecting the root bridge. We can achieve this, because there is no authentication mechanism build into the STP
D3) What are TACACS+ and RADIUS?	Both are protocols used to provide authentication, authorisation and accounting in a network as well as Access Control. Terminal Access Controller Access-Control System Plus (TACACS+). TACACS+ is a Cisco proprietary protocol (TCP/49). Remote Authentication Dial In User Service (RA-

	DIUS) is open standard so can be used with non-cisco hosts. It uses UDP 1812 and 1813. All AAA packets are encryped in TACACS+ but only passwords are encrypted in RADIUS
D3) TACACS+ Vunerabilities	No integrity checking to make sure the packets have no been tampered with. No protection against replay attacks (as long as a packet has the correct TACACS+ sequence number, it will be accepted). Session ID collision (encryption mechanism for TACACS+ depends heavily on session if for each session). Session ID randomness (session IDs will eventually be reused, which can result in the decryption of packets). Lack of padding (could reveal the length of a user password). MD5 context leak (theoretical vulnerability exists whereby

	part of a packet may be decrypted, due to the presence of certain bytes.
D4) What is IPSec?	IPsec is a group of protocols that are used together to set up encrypted connections between devices. It helps keep data sent over public networks secure. IPsec is often used to set up VPNs, and it works by encrypting IP packets, along with authenticating the source where the packets come from. Within the term "IPsec," "IP" stands for "Internet Protocol" and "sec" for "secure." The Internet Protocol is the main routing protocol used on the Internet; it designates where data will go using IP addresses. IPsec is secure because it adds encryption* and authentication to this process.
D4) What problem does IPsec solve?	

IP is inherently insecure. It is possible to intercept/manipulate traffic between sender and receiver meaning that you can: sniff network traffic, spoof IPs, modify data packets and replay attack. IPSec is designed to provide security for the Internet Protocol as it allows secure, encrypted communication between endpoints.

D4) IPsec vs SSL/TLS?	Another protocol for VPNs is SSL/TLS, which operates at a different layer in the OSI model than IPsec.
D4) How do you connect to an IPSec VPN?	Users can access an IPsec VPN by logging into a VPN application, or "client." This typically requires the user to have installed the application on their device. VPN logins are usually password-based. While data sent over a VPN is encrypted, if user passwords are compromised, attack-

	ers can log into the VPN and steal this encrypted data.
D4) What are the components of IPSec? (3)	Internet Key Exchnge (IKE), Encapsulating Security Payload (ESP) and Authentication Header (AH)
D4) What happens in IKE?	Internet Key Exchange. This provides authentication and key exchange for establishing and maintaining IPsec communications. It uses 3 forms of authentication: pre-shared keys (PSK), public key encryption and digital signatures. These are used to authenticate the 2 parties and decide on tunnel parameters such as which hash they will use (MD5/SHA1), which authentication (RSA), which Group (DH, asymmetric encryption), Lifespan and Encryption (AES/DES). This stage is called Security Association.
D4) IKE vs ISAKMP?	

Internet Security Exchange and Key Management Protocol (ISAKMP) is part of IKE. (IKE has ISAKMP, SKEME and OAKLEY). IKE establishes the shared security policy and authenticated keys. ISAKMP is the protocol that specifies the mechanics of the key exchange.	
D4) How would you identify a device running an IPSec service? Attack it?(2 + 1)	Exposed UDP port 500. ike-scan utility will scan ranges for the presence of IKE VPN services (using -q flag). Can also fingerprint a VPN server using the -M -o flags. Attacking it you could reverse engineer the set of conditions they agreed on during IKE.
D4) IKE Phase 1 Modes?	Main or Aggressive: Main mode is more secure and has more steps, aggressive is faster and skips a few steps.
D4) What happens in Authentication Headder (AH)	

This is the next step of IPsec after IKE. It provides protection from data modification and replay attacks. Integrity checks on the packet header, would complain if the external IP changed

D4) What happens in ESP?

Encapsulating Security Payload (ESP) is the next step of IPsec after IKE and AH. It encapsulates and encrypts IP datagrams

D4) How does IPsec work?

IPsec connections include the following steps: 1) Key exchange: Keys are necessary for encryption; a key is a string of random characters that can be used to "lock" (encrypt) and "unlock" (decrypt) messages. IPsec sets up keys with a key exchange between the connected devices, so that each device can decrypt the other device's messages. 2) Packet headers and trailers: All data that is sent over a network is broken down into smaller pieces called packets. Packets contain both a payload, or the actual data being sent, and headers, or information about that data so that computers receiving the packets know what to do with them. IPsec adds several headers to data packets containing authentication and encryption information. IPsec also adds trailers, which

go after each packet's payload instead of before. 3)Authentication: IPsec provides authentication for each packet, like a stamp of authenticity on a collectible item. This ensures that packets are from a trusted source and not an attacker. 4)Encryption: IPsec encrypts the payloads within each packet and each packet's IP header. This keeps data sent over IPsec secure and private. Transmission: Encrypted IPsec packets travel across one or more networks to their destination using a transport protocol. At this stage, IPsec traffic differs from regular IP traffic in that it most often uses UDP as its transport protocol, rather than TCP. TCP, the Transmission Control Protocol, sets up dedicated connections between devices and ensures that all packets arrive. UDP, the User Datagram Protocol,

does not set up these dedicated connections. IPsec uses UDP because this allows IPsec packets to get through firewalls. Decryption: At the other end of the communication, the packets are decrypted, and applications (e.g. a browser) can now use the delivered data.

D5) What is VoIP?

VOIP is an acronym for Voice Over Internet Protocol, or in more common terms phone service over the Internet. If you have a reasonable quality Internet connection you can get phone service delivered through your Internet connection instead of from your local phone company. Can be used for phone calls over IP network, IP phone to PSTN connectivity, Voicemail and Video calling.

D5) What is PPTP?

Point-to-point tunnelling protocol (PPTP) is commonly used to provide remote access to mobile devices. It uses TCP/1723 for key exchange. It encrypts data between peers using IP protocol 47 and Microsoft-CHAP for authentication.

D5) Fingerprinting PPTP?	Nmap can be used and just look for TCP/1723 being open.
D5) Attacking PPTP Services?	thc-pptp-bruter will bruteforce PPTP serviccs by trying taking a username and trying to bruteforce the MS-CHAP password
D5) What is SIP?	Session Initiation Protocol (SIP), SIP is the signalling protocol for VOIP. Responsible for setting up, managing and terminating the connection. Uses TCP/UDP 5060. Plaintext protcol. Sniffable. (Similar to HTTP).

D5) H.323 vs SIP	Both are transfer protocols for VoIP. H.323 older and has now started being replaced with SIP.
D5) SIP Methods?	6 methods. REGISTER, INVITE, ACK, CANCEL, BYE, OPTIONS. 1) REGISTER is used to register with a SIP server. Clients gives its name as if plugging into a Private Automatic Branch Exchange (PABX). Normally one name is registered. 2) INVITE, ACK, CANCEL used to set up a call session. INVITE is used to invite someone to join a call and is likeup dialup. 3) BYE terminates a session. 4) OPTIONS is the only method that does not resolve any calls. OPTIONS shows what methods are supported by the server. OPTIONS MUST be supported to be RFC compliant (unlike HTTP)
D5) SIP servers (3+1)	

Number of different server types like: Registrar server which stores names and addresses, Proxy Server which forwards call requests and Redirect servers which find locations of end-points. One of the most common servers encountered is Asterisk which you can google dork for

D5) SIP Enumeration and Fingerprinting

1)Firstly, connect to the port and issue and OPTIONS request. ALLOW shows what methods are supported by the SIP server. 2) Google dork for Cisco Phones, Asterisk, Polycom etc. 3) See if you can find an Asterisk call manager found on port 5038. 4) SVMap (part of the SIPVicious Suite). sip-proxy nmap script will reveal the methods supported, swwar (SIP Vicious War Dialer) will enumerate extensions, SVcrack will bruteforce PBX extension passwords. If you can login

	you may be able to check voicemail etc.
D5) SIP Security	Authentication) Used to use basic authentication in the clear. Digest no sends a challenge that is passed back encrypted with MD5. Encryption)ssl/tls although is optional, standard implementation is over UDP although ideally would be over TCP.
D5) Signalling vs Media Packets	Signalling packets are about setting up the communiction (with SIP or Session Initiation Protocol) within VoIP. Media packets carry the actual content.
D6) IEEE 802.11 standards	a, b, g, n and ac
D6) IEEE 802.11a	Max Speed: 54 mbit/s, Frequency 5/3.7GHz, Modulation type OFDM
D6) IEEE 802.11b	Max Speed: 11 mbit/s, Frequency 2.4GHz, Modulation type DSSS
D6) IEEE 802.11g	

Max Speed: 54 mbit/s, Frequency 2.4GHz, Modulation type DSSS, OFDM	
D6) IEEE 802.11n	Max Speed: 150 mbit/s, Frequency 2.4G/5Hz, Modulation type OFDM
D6) IEEE 802.11ac	Max Speed: 866 mbit/s, Frequency 5GHz, Modulation type OFDM
D6) 2.4GHz Channels and Frequencies	802.11 b, g and n use 2.4GHz. It is dividede into 14 channels
D6) 5GHz channels and frequencies	802.11 a, n and ac use 5Ghz. Less crowded frequency range. 40Mhz channel bandwidth meaning you can transfer more data.
D6) WEP	Wired Equivalent Privacy. First attempt to secure Wi-Fi. Completely ineffective due to security flaws. It uses RC4 stream cipher in conjunction with a 40 or 104 bit key.
D6) Wireless IV?	

	Initialisation Vector. RC4 internal state reset on every frame. Every frame encrypted with the same keystream so same result produced over and over. To solve this we use a 24-bit initialisation vector prepended to the key. It is sent unencrypted with the cipher text and allows decryption.
D6) What is wrong with IV?	RC4 needs a unique IV to prevent repition. 50% probablility that IV will repeat after 5000 packets. In a busy network repititions happen frequently.
D6) TKIP?	Temporal Key Integrity Protocol. Enryption algorithm used within WEP. It is a suite of algorithms,. Uses RC4. 128-bit encryption key.
D6) WPA?	Wi-Fi protected access. Intermediate security protocol that will replace WEP. Implements a Message Integrity

	Check which prevents packet tamper-ing.
D6) WPA2?	Replaced WPA and implements mandatory elements of 802.11 stan-dard. CCMP - AES based encryption
D6) Wireless authentication modes (4)	Open authentciation, MAC-based ac-cess control, Pre-Shared Keys (PSK), WPA2 Enterprise with 802.11x au-thenticaton
D6) Wireless authentication protocols (3)	additional authetnication protocols were required to bolster WEP. A num-ber of competing methods emerged which provide stronger authentication and means to derive/distribute keys to network clients. The protocols are: EAP, LEAP and PEAP.
D6) EAP	Extensible Authentication Protocol (EAP) provides authentication for point-to-point connections and wire-less connections. Primary authentica-

	ton method for WPA/WPA2. Defines a message format.
D6) LEAP	Lightweight EAP. Created by Cisco, not used by Windows, uses a modified version of MS-CHAP. Passwords can be compromised using the ASLEAP tool.
D6) PEAP	Protected EAP. EAP encapsulated in a TLS tunnel. Joint project.
D6) Wireless enumeration tools	aircrack-ng suite. Suite of tools for enumeration and exploitation. Airmon-ng places wireless interfaces in monitor mode. Airodump-ng is a powerful wireless sniffing tool (automatic channel switching, filter captured traffic by cipher suite, deterine clients connected to an AP, determine clients MAC addresses). Aircrack-ng is a key cracking tool. Airdecap-ng decrypts captured files. Wireshark.
D7) Hubs vs Swithces	

Hubs are unmanaged network devices. They have no IP. They repeat traffic to all ports on all devices. Switches can be managed or unmanaged (cisco is managed). SNMP or Telnet can be used to manage. Switches have an IP address.D7) Routers - Routers have 1 IP per interface. Layer 3 devices. Offer services for device management including HTTP, HTTPS, SNMP, SSH, Telnet etc.	
D7) IDS	Intrusion Detection System. Distracts testers away from testing. Solution is to put IDS in monitor mode or put the tester IP into their access list.
D7) Cisco Routers	Cisco is the most popular vendor for routers. It uses Interworking Operating System (IOS) which means it can support multiple OS (XP, Vista etc). The

	software comes in major versions and patches.
D7) Find a version of Cisco router?	HTTP: config file? SNMP: System.SysDesc.0. Telnet/SSH (once authenticated) router > show ver. Telnet/SSH (unauthenticated) User Access Verification/Password
D7) Firewalls vs Routers	Firewalls can make changes to packets, routers can't. They use Network Address Translation for mapping of IPs. They use Port Address Translation for mapping of ports. No TTL decrement. Have a state table whereas routers dont. Firewall used to control access
D7) How do firewalls control traffci (3)	Network level (IP address): what address can talk to each protected system. Transport level: what port/services. Application level: what mail/web

	commands can be used. Does not apply to Link Level (MAC address)
D7) Firewall rules	DEFAULT PERMIT allows everything and blocks bad traffic. Does not work as not ALL badd traffic can be identified. DEFAULT DENY allows good traffic only and denies everything else. Cisco and Checkpoint have different jargon. First match in the rules that it finds it uses that and most firewalls will drop packet it no match.
D7) ANY firewall rule	ANY should raise alarms. As a source it should only be used in it a public server. As a service it shouldn't be used. As a destination you should ask if it is really publicly accessible. Never allow ANY outbound traffic.
D7) STEALTH RULE	rule that blocks access to the firewall IP adddress at the top of the rule base.
E1) What is NetBIOS?	

1) NetBIOS provides communication services on local networks. It uses a software protocol called NetBIOS Frames that allows applications and computers on a local area network to communicate with network hardware and to transmit data across the network. 2) It lies between transport/application level. 3) It can be used with 3 different Network layer protocols: IPX, NetBEUI (NetBIOS Frame) andIP.

E1) What services does NetBIOS provide (3)

NetBIOS provides 3 services to upper level. 1)"Name Service" for Name registration and name resolution. 2) "Session Service" for Connection-oriented session between 2 systems. 3) "Datagram Service" for Connectionless service between any systems.

E1) NetBIOS Names? (4)

1) NetBIOS names are ALWAYS 16 characters long. 15-character name and 1-character suffix which is displayed in hex. 2) 2 types of names are 'Unique' and 'Group'. 3) Names are hard to manage as it is a 'flat namespace'. 4) Problems arise when for example merging companies/domains. There would be a conflicit of namespace as there is no hierarchy associated.	
E1) nbstat? (3)	nbtstat is a standard windows command which works for NetBIOS over TCP. nbtstat lets you look at NetBIOS name table (for local and remote). -a gives you all the details
E1) NetBIOS over TCP? (1 + ports)	NBT or NetBT is NetBIOS over TCP. Described in RFC-1001 and RFC-1002. Name Service (UDP/137). Datagram Service (UDP/138) is connectionless.

	Session Service (TCP/139) is connection-oriented.
E1) Domain/Workgroup Idenfitication?	1) Verify NetBIOS services are running. "nmap -sS -p139,445 192.168.147.0/24". 2)
E1) NetBIOS suffix?	1) These are the 2 characters after a name and can indicate the services offered and server role. 2) 00 = workstation, 1C = domain controller etc etc. U is only one IP address assigned, G is a group and may have multiple IP addresses
E1) NetBIOS domain/workgroup assumptions from looking at nbstat/suffixes? (3)	1) Computer is a Domain Controller (DC) if Domain Controllers (<1C> / G). 2) Computer is part of a Workgroup and NOT domain if MSBROWSE (<01> / G) with no Domain Controllers (<1C> / G). 3) Computer is part of domain if neither MSBROWSE nor Domain Controllers.
E1) Workgroup vs Domain	

1) In a workgroup, all computers are peers, no control over another one whereas in Domains there are servers. 2) You need individual accounts on each computer in a workgroup, whereas if you have domain creds you can login to any comp. 3) WG = 10-20, 100-1000s 4) WG all on the same local network vs can be on different ones	
E1) Domain Controller vs Master Browser suffixes	DC = 1C/G, MSBROWSE = 01/G
E1) Getting FQDN/OS of a machine on the network? (3)	ldapsearch -x -h -p389 -s ase '(objectclass=*)'. 2) nmap -script smb-os-discovery. 3) smbversion (metasploit)
E1) Why focus on the DC?	Focus on Domain Controllers (but not PDC). Systems that may hold critical data such as: database servers (MS SQL Server), mail servers (MS Exchange Server) and file servers.
E1) What is Windows Browser Ser-	

Browser service or Computer Browser Service is a feature of Microsoft Windows to let users easily browse and locate shared resources in neighboring computers. This is done by aggregating the information in a single computer "Browse Master" (or "Master Browser"). All other computers contact this computer for information and display in the Network Neighborhood window. A backup browser is chosen by the Master Browser.

E1) How to identify master browser?	Iservers. This will give NAME OS-VERSION MBR/BBR/PBR *PDC*/BDC SVR/WKS
E1) SMB vs CIFS?	Almost the same thing, no one has explained the difference. SMB/CIFS provides shared access to files, printers and other shared resources.
E1) What is an SMB share?	

Sounds obvious, is just a shared resource. It is identified by a name e.g \\server1\technical. $ suffix means it is hidden, commonly there is C$, D$ and ADMIN$ which are administration shares. IPC$ isthe inter-process communication and is accessible by all users.	
E1) DCE/RPC vs ONC/RPC	DCE/RPC is a windows variant of RPC (aka MSRPC). All Windows versions have an endpoint mapper running on port 135 (tcp/udp). Endpoint mapper used for all client/server interaction (except AD) e.g. DCOM, event viewer allows to connect to different systems. 2) ONC/RPC more UNIX/Solaris and is on port 111.
E2) User enumeration via NetBIOS?	Using null session (unauthenticated). Connect to IPC$, if established can enumerate USERS and GROUPS and

	SHARES. Really there should be no privileges across the network for Null session.
E2) Tools for NetBIOS username enueration? (4)	enum (windows), enum4linux (linux). getAcct (Windows, smb_enumusers (metasploit)
E2) User enumeration via SNMP?	1. SNMP (Simple Network Management Protocol) services listen on UDP port 161. 2. The SNMP MIB (Managed Information Base) data can be retrieved from a device by specifying the correct read community string.
E2) Tool for SNMP username enumeration	snmp_enumusers (metasploit) , snmpwalk -c public 192.168.51.29 .1.3.6.1.4.1.77.1.2.25
E2) User enumeration via LDAP?	Runs off port 389 and acts like a phone directory or dictionary. cn = common name. Can gather information about a system using a NULL bind.

E2) Tools for LDAP username enum?	ldapsearch -x -h 192.168.0.1 -p389 -s base '(objectclass=*)'. ldapsearch -x -h 192.168.0.1 -p389 -s sub '(objectclass=*)
E3) Main components of AD? (3)	LDAP provides directory service. DNS provides name service. Kerberos provides authentication service. Version 5 is used
E3) AD Objects?	Objects stored in a hierarchy not a flat namespaces. Objects include Resources, services, users and groups, containers (similar to folders).
E3) AD structure?	FOREST is the top level. TREE is a level down from FOREST instance. Each TREE have different namespaces. Trust between TREES. DOMAIN is a level down from TREE instance. Shares resources like users, groups, etc. Trust between DOMAINS
E3) AD Domain Controllers	

1) All AD Domain Controllers (DC) are multimasters. There is no concept of master-slave. Each DC is equivalent and have read-write privileges. Changes can be made on any DC.• DC Security requires protection of critical data. Compromise of DC compromises whole domain. 2) Flexible Single Master Operations (FSMO) roles. First DC usually takes FSMO roles. Special roles for DC in a domain where tasks not suited to multi-master replication. FSMO roles include: PDC Emulator, Relative ID Master, Infrastructure Master. 3) Global catalog has details of users and list of resources for domains.

E3) NTDS.dit

The Ntds.dit file is a database that stores Active Directory data, including information about user objects, groups, and group membership. It

	includes the password hashes for all users in the domain.
E4) Admin account brutefroce	Adminstrator never locked out.
E4) Windows Authentication Methods (3)	1) Oldest is LAN Manager, not supported by every OS, weak encryption. 2) NTLM v1 uses Lanman DES, can be more than 14 characters, stronger than LM. NTLM v2 uses NT MD4, server-client communication with random number challenges and shared secrets (password hash). 3) Kerberos v5 used by 2000, 2003, XP when in a domain
	1) Local Authentication details are stored in SAM (Security Accounts Manager). There is a protected registry area where even administrator cannot read it. SAM stores LM + NTLM Hashe. 2) Domain Authentication details are stored in the ACTIVE DIRECTO-

E4) Local Vs Domain Authentication	RY. Active Directory shares LM + NTLM hashes. Local Secrity Authority (LSA) handles longin and maintains a database of secret information. LSA secrets has credentials for services that run as local users. Debug properties can be used to dump LSA secrets.
E4) Offline password cracking tools (5)	Tools that can perform checks are lcp (lc5), lophtcrack (need licence), ophcrack, john and cain & abel. Rainbow tables are precompiled tables for reversing cryptographic hash functions for cracking password hashes. By extracting these hashes, it is possible to use tools such as Mimikatz to perform pass-the-hash attacks, or tools like Hashcat to crack these passwords.
E3) AD Trust Model	

Two-way (No real separation between domains). Transitive. Implicit trust within forest. Separation between forests. In 2003, forest roots are trusted. Tool: nltest. Trust doesn't grant access. Just gives the ability to grant access. ACL is required. No access by default.	
E3) Group Policy	A way to manage computer and user settings. Managed centrally in Active Directory (AD). Alternative to local policy registry changes. Easier to manage and scalable. Computer policies (processed at boot) and User policies (processed at login). Net Command can be used to add accounts and groups.
	Registry is a hierarchial configuration database. The hierarchy is formed of keys and values. Similar to folders and

E3) Windows Registry	files in a directory tree. Keys are container objects. Values are Name, Type or Data. Types include REG DWORD and REG SZ.
E5) Windows common post-exploitation activies (6)	obtain password hashes, both from the local SAM and cached credentials. obtaining locally-stored clear-text passwords. crack password hashes. check patch levels. derive list of missing security patches. reversion to previous state
E5) Windows Vulns (5)	1) Password guessing. 2) Lack of OS and application patches. 3) Authentication credentials on the file system if any. 4) Vulnerable services. netstat gets a process listing. 5) Writeable system files. Executable to write. e.g. replace a service owned by an administrator.
E5) Public Windows Exploits to know about (3)	

ms03-026 (Buffer Overrun In RPC Interface Could Allow Code Execution). ms08-067 (Vulnerability in Server Service Could Allow Remote Code Execution (958644). ms09-001 (Vulnerabilities in SMB Could Allow Remote Code Execution)	
E5) Windows Priv Esc?	Look AT scheduling. Look for writable executable files. Look for services that run executable files that can be modified by any user. Overwrite with executable that can write file.
E5) Windows Password Grabbing	SAM is protected and not readable. pwdump is a family of tools to dump passwords. Need admin access. pwdump2 and 6 most popular (different versions for different versions of windows
E5) Get Windows patch levels whilst on system?	

"systeminfo" gives a partial list of patches. (Standard user). "wmic qfe" gives a complete list of patches installed. 'HKLM\Software\Microsoft\Updates\' and 'Microsoft\Windows\NT\Current Version\Hotfix' . "Add/Remove Programs" (appwiz.cpl) may list some Microsoft security patches installed and when.	
E6) What is a service pack?	Service Pack is a collection of patches and new features. Patches are defined as "hotfixes" in Microsoft.
E6) Microsoft patching schedule?	Release scehdule occurs 2nd Tuesday of every month and known as "patch tuesday". Some patches released at other times. Attackers try to announce vulnerability or attack on "exploit wednesday". Every patch requires a reboot. Critical servers are not

	necessarily patched as soon as patch is released.
E6) List patches on machines? (various OS)	To list what patches are installed in XP, 2003 use 'wmic qfe'. To list what patches are installed in NT, 2000 use 'HKLM\Software\Microsoft\Updates\' and 'Microsoft\Windows\NT\Current Version\Hotfix'
E6) What is SMS	Systems Management Server. SMS now called System Center Configuration Manager. Provides remote control, patch management, software distribution, operating system deployment, network access protection and hardware/software inventory.
E6) What is WSUS? (5)	

Windows Server Update Services (WSUS). Earlier version called Software Update Services (SUS). Enables administration and distribution of updates and hotfixes released for Microsoft products in corporate environment. WSUS downloads updates from Microsoft Update website and then distribution them to computer on local network. WSUS allows administrators to check updates against their systems. WSUS gives no control to user.

E6) What is MBSA? (3)	Microsoft Baseline Security Analyzer (MBSA). Software tool to determine security state by assessing missing security updates and less secure security settings. Can use offline scan file, wsusscn2.cab (30MB) to compare against
E7) Windows Desktop Breakout Physical	

Physical Access is unconstrained. Real locks required to stop people opening systems up. Boot from CD or USB should be disabled. OS can be mounted from these systems. Install new primary Disk. Boot off same primary disk. Reset BIOS password (Remove NVRAM battery or reset password jumper). BIOS should be blocked with a password set. Problem if BIOS allows the order to be changed.	
E7) Linux Boot Loader	LILO/GRUB used in Linux. Left-shift (F8). Kernel is loaded and parameters is added. e.g. init = /bin/bash/
E7) Application breakout	Password Guessing. Writable system files. Vulnerable Services. Credentials in scripts or text files. Missing OS or application patch
E8) What is Microsoft Exchange	

Microsoft Exchange Server is a mail server and calendaring server developed by Microsoft. It runs exclusively on Windows Server operating systems. In layman's terms, it's a piece of software that runs on a server and manages all your emails. Incoming, outgoing, saved, drafts, calendars-everything is done through Microsoft Exchange and stored on the server.

E8) Outlook and Microsoft Exchange

Exchange is the software that provides the back end to an integrated system for email, calendaring, messaging, and tasks. Outlook is an application installed on your computer to communicate with it. Outlook is the client used to provide access to POP3/IMAP, calendar, contacts. Protocol used is MAPI/RPC (exchange RPC). Very messy to lockdown. Mes-

	saging Application Programming Interface (MAPI). Outlook Web Access (OWA) is the web interface.
E8) Securing Exchange/OWA?	Use IPSEC to secure channel between OWA on DMZ and Exchange server on corporate network. Can even use ISA server.
E8) Vulnerabilities in exchange? (4)	• ms03-047: Vulnerability in Exchange Server 5.5 Outlook Web Access Could Allow Cross-Site Scripting Attack. ms07-026: Vulnerabilities in Microsoft Exchange Could Allow Remote Code Execution. ms09-003: Vulnerabilities in Microsoft Exchange Could Allow Remote Code Execution. ms12-058: Vulnerabilities in Microsoft Exchange Server WebReady Document Viewing Could Allow Remote Code Execution
E9) Common Remote Desktop Windows Applications (4)	

1) Remote Desktop Protocol (uses port 3389). Replaced Windows Terminal Services. rdesktop is the linux version. Encrypted with RC4 cipher. 2) VNC = Virtual Network Computing, platform independent (TCP/5900 to 5906). 3) RealVNC = Remote authentication bypass allows users to connect to it (CVE-2006-2369). 4) PC Anywhere = Largely replaced by VNC/RDP (TCP/5631, UDP/5632. Versions 10.5 and 11.x where x<5 have vulnerabilities in service.

Generally, they need to run as high priv user. Arcserve 11.5 has a Remote Command Exceution Vulnerability that allows a specially crafted RPC packet. Veritas Backup Exec has Remote Command Execution Vulnerability that allows a buffer overflow. Versions vulnerable 8.x where x<60

E9) Common windows backup/antivirus programs and their vulns	and 9.x where x<1. (CVE-2004-1172). Symantec Anti-Virus and Client Security has a number of vulnerabilities. In particular Anti-virus up to version 10.1 and Client Security up to version 3.1. Remote command execution and buffer overflow in rtvscan.exe (CVE-2006-2630).
F1) Unix User Enumeration Tools (4)	rusers, rwho, SMTP and finger
F1) rusers	rpc.rusersd service can be queried to see who is logged into the UNIX machine and for how long. "rpc.rusersd" is a daemon (server program) and lists users that are logged in on server. A client program for querying this information is built into most UNIX systems called rusers. There are two ways of running this program. Simply typing in rusers on the command line will broadcast a query to all near-

	by hosts. (i.e. rusers). Specifying host hame will query more detailed information from just that one machine. (i.e. rusers 192.168.0.1)
F1) rwho	"rwho" protocol provides a simple scheme for listing UNIX machines on the local segment, and who is logged onto those machines. Each UNIX host runs a daemon (usually "rwhod" or "in.rwhod") that both periodically broadcasts its information, as well as listens for other machine's broadcasts. Each machine then keeps a list of active machines and logged on users. The broadcast from each machine is a UDP packet sent to port 513. (DO NOT CONFUSE WITH tcp/513). "in.rwhod" daemon runs on server. It is a producer and consumer of information. "in.rwhod" broadcasts every 3 minutes. It maintains a data-

	base of "rwho" and "rupdate" information. "rwho" is a client that queries the database. Usually comes with "in.rwhod". "ruptime" is a client that queries the same database.
F1) SMTP User enum	Simple Mail Transfer Protocol (SMTP) is very simple and is used to send email messages. SMTP runs on tcp/25. RFC821 (1982). SMTP is a plaintext protocol and offers no authentication. SMTP AUTH extension can be used to authenticate a SMTP client. There are a number of commands that can disclose usernames based on different responses to valid and invalid users. Methods that leak information: EXPN, VFY, RCPT TO. "EXPN " expands address. It is a bug and shouldn't be supported. "RCPT TO: " is recipient address. If Recipient is OK, RCPT responds with

	a status of 250 2.1.5. If not found, it responds with a 550 error or nothing returned. "VRFY " verifies address. It is a bug and shouldn't be supported. Example = VRFY root 250 Super-User . VRFY blah 550 blah... User unknown
F1) Finger (general info)	Finger used to find out user status and information. Finger daemon runs on TCP port 79. RFC742 (1979). Finger is a plain text protocol with no authentication. Finger is a protocol. Finger is a client program. Finger is a server program. Server program called Service (Windows) or Daemon (Linux/Unix). Daemon is fingerd or in.fingerd (for Internet).
F1) How does Finger work	

Remote User Information Program (RUIP) is started on the remote end of the connection to process the request. Local host sends the RUIP one line query based upon the Finger query specification, and waits for the RUIP to respond. RUIP receives and processes the query, returns an answer, then initiates the close of the connection. Local host receives the answer and the close signal, then proceeds closing its end of the connection.

F1) Why is finger no longer around	Finger protocol is also incompatible with Network Address Translation (NAT) from the private network address ranges (e.g. 192.168.0.0/16). For these reasons, by the late 1990s the vast majority of sites on the internet no longer offered the service.
F1) Finger vulnerabilities	

finger daemon has also had several exploitable security holes which crackers have used to break into systems. Morris worm (1988) exploited an overflow vulnerability in fingerd (among others) to spread. Information leakage when you use 0@ (finger zero) as finger matches against user and GCOS. If GCOS is empty, the user is matched. It also has many information disclosure issues too such as finger search.@host Attack: finger search.**@target. Finger dot at host Attack: finger .@target. Finger Redirection Attack: finger user@host@victim. FreeBSD 4.1.1 Finger: finger /etc/passwd@target. infingerd pipe: finger |command to execute@target

F2) Linux common post-exploitation activities

exfiltrate password hashes. crack password hashes. check patch levels.

	derive list of missing security patch-es.reversion to previous state
F2) Solaris Vulns (4)	1) Calendar Management Ser-vice Daemon (CMSD) is run on port 32779. rpc.cmsd is owned by bin BUT run as root. CMSD Buffer Overflow Vulnerabili-ty, CA-1999-08.html, CVE-1999-0696. Solaris 8 and earlier are vulnera-ble. CMSD Buffer Overflow Vulner-ability, CVE-2010-3509. Solaris 10 and earlier are vulnerable. 2) Telnet ttyprompt vulnerability causes priv-ilege escalation, CA-2001-34.html, CVE-2001-0797. Solaris 8 and earlier are vulnerable. 3) Kodak Color Man-agement Server (KCMS) Vulnerability permits any file to be read as root, CVE-2003-0027. Solaris 9 and earlier are vulnerable. 4) sadmind root com-mand execution vulnerability affects

	Solaris 9 and earlier, CVE-2003-0722. sadmind adm build path() Buffer Overflow affects Solaris 9 and earlier, CVE-2008-4556. METASPLOIT CAN BE USED FOR THESE
F2) Linux vulns	1. General lack of patch management for the OS. 2. Outdated third-party applications. 3. Lack of password enforcement 4. General lack of system hardening 5. Lack of backups
F2) Unix Post exploitation (Password and shadow)	Shadow file is /etc/shadow in Linux/Solaris. Shadow file is /etc/master.passwd in BSD.
F2) Unix Post Exploitation (Password Cracking)	John the Ripper, John merges password and shadow file but is CPU-intensive. John has 3 different modes.1. Single-crack mode, which is based on username/gcos. 2. Word-list, which uses a permutated dictionary attack and additional numbers. 3. Incremen-

	tal, which uses a brute-force attack. Can tune each of these modes. If you get a number of passwords, could apply password policy.
F2) Unix Package and Patch Management	Package is an installed software. Patch is a security update/bugfix. Different distributions have different programs to update. Redhat (fedora, redhat entrprise, centos...), debian (debian, ubuntu), solaris. Redhat and Debian do not have separate command for patches. Tarball is source code to compile. Debian backports the version, so may look like a vulnerable version.
F2) Patch management programs Unix	Redhat uses redhat package management (RPM). "rpm -qa" # q=query; a=all. Debian uses dpkg. "dpkg -l". Solaris uses pkginfo, showrev, patchadd. "pkginfo" ."showrev -a". "showrev -p"

	# shows installed patches. "patchadd -p" # requires root, very slow
F3) FTP Active vs Passive Mode	There are 2 modes. Active mode and Passive mode. Passive Mode is newer. FTP clients have active mode on by default. (Command Line). Web broswer uses passive mode. Active Mode = Client tells server what port data will be sent from, can cancel transfer. Passive = Server tells client what port to use. Remember, TCP 21 is control channel, TCP 20 is the data channel.
F3) Issues with FTP	Everything passed in the clear including username/password. Anonymous FTP used for public FTP sites. Write access can allow storage of rubbish files. USER: ftp, anonymous. PASSWORD: , (e.g. x@y>
F3) FTP Bounce attack	

This is only on passive mode where the client tells the server what to do. You initiate a connection with the FTP server but instead of putting your own IP for the server to connect to you put a 3rd machines IP and the FTP server will make a connection to that machine. You will then effectively have FTP access to that machine and can 'ls' or send files.

F4) Sendmail?	Sendmail is a Message Transfer Agent (MTA).
F4) What is MTA?	A mail server can have many names: mail relay, mail router, Internet mail-er. But the most common alias is an MTA. This may refer to a mail transfer agent, a message transfer agent, or a mail transport agent. No matter which name you use, MTAs play an essential role in the Internet message handling

	system. They transfer electronic mail messages between users. In this article, we'll explore how MTAs work, what effect they have on email deliverability, and many other related questions.
F4) Open mail relay?	Open mail relay is a SMTP server configured such that it allows anyone on the Internet to send e-mail through it, not just mail destined to or originating from known users.
F4) POP-3	1. POP3 listens on TCP port 110 and TCP port 995 (SSL/TLS). It provides email services
F4) IMAP	IMAP services run on TCP port 143. It is much the same as POP3; user authenticates with plaintext network service and then manage and collect email
F5) What is NFS?	

NFS (Network File System) is used for diskless workstation solution to a network server. Many versions from 1984 - 2000. It allows file sharing between multiple servers. Very easy to use, servers already have a kernel and so can mount stuff easily in most cases. Servers controls what can be exported and to who. NFS supports up to 10-20 clients. Tool: showmount. Option 'e' shows exports.

F5) Root squashing, nosuid and noexec

root squashing is when you upload someting to an NFS mount as root and instead of it being uploaded and owned by 'root', as would be expected, it uploads it as 'nobody' which means it has reduced privileges. nosuid, Disables set-user-identifier or set-group-identifier bits. This prevents remote users from gaining higher privileges by running a setuid

	program. noexec, Prevents execution of binaries on mounted file systems.
F6) What are R* services	Refer to a class of remote tools in UNIX systems. The most popular are "rsh" for a remote shell, "rlogin" for a remote login, and "rexec" for remote execution. Propreitary protocols used in BSD/Unix. rlogin (TCP/513) is used for remote login (similar to telnet). rsh (TCP/514) is used for remote command execution. Authentication based on source IP address. rlogin and rsh are cleartext protocols. rwho, rusers, rstatd, rexec.
	The . rhosts file is the user equivalent of the /etc/hosts. equiv file. It contains a list of host-user combinations, rather than hosts in general. If a host-user combination is listed in this file, the specified user is granted

F6) what is rhosts?	permission to log in remotely from the specified host without having to supply a password. Entries have one or two variables. "host" allows specified host with same user. "host user" allows specified host and user. "+" character is wildcard.
	If hackers can capture a user ID and password by using a network analyzer or can crash an application and gain root access via a buffer overflow, one thing they look for is what users are trusted by the local system. That's why it's critical to assess these files yourself. The /etc/hosts.equiv and .rhosts files list this information. The $home/.rhosts files in Linux specify which remote users can access the Berkeley Software Distribution (BSD) r-commands (such as rsh, rcp, and rlogin) on the local system without

F6) rhosts/hosts.equiv files	a password. The /etc/hosts.equiv file won't give away root access information, but it does specify which accounts on the system can access services on the local host. For example, if tribe were listed in this file, all users on the tribe system would be allowed access. As with the .rhosts file, external hackers can read this file and then spoof their IP address and hostname to gain unauthorized access to the local system. Hackers can also use the names located in the .rhosts and hosts.equiv files to look for names of other computers to attack.
F6) Securing rcommands	Badly configured trusts allow attacker access. "+ +" allows any host and any user to connect. VERY BAD. Trust host concept is obsolete. R services should not be used in a modern environment.

F6) rwho	rwho uses udp/513 but has no rfc. Not to be confused with rlogin (tcp/513). in.rwhod runs on a server. It is a producer and consumer of information. broadcasts every 3 minutes, uptime and who is on the system, keeps a db of what it has. "rwho" is a client that queries the database (comes with in.rwhod). "ruptime" is a client that queries the same database. listen with wireshark/tcpdump as everything is in the clear
F6) rusers	"rusers" has nothing to do with 'rwho' and is a RPC program. "rusersd" is a server program and lists users that are logged in on server. "rusers" is a client that shows who the users on the server are. (classic client-server model). "rusers" has a broadcast mode to find which servers available.
F6) rstatd	

"rstatd" is a RPC program. Sometimes seen as rpc.rstatd and not to be confused with stat.d (used in nfs). It is kernel statistics server (doesn't provide status). 2 clients for rstatd: rup (remote uptime) and rsysinfo (remote sysinfo). This should not be seen on production systems

F6) rexec

rexec is remote command execution. rexec runs on tcp/512. rexec can be confused with rsh and rlogin. Difference in authentication. Authentication with username/password (not rhosts). rexecd is a server program, only seen on Solaris. rexec allows root access (execute remote shell over rexec).

F7) What is X Windows?

The X Window System (X11) is an open source, cross platform, client-server computer software system that provides a GUI in a distributed network environment. 1. Used in UNIX like OS'es as underlying system for displaying graphical applications 2. X Servers listen on TCP ports 6000 to 6063 3. The host based X authentication allows users to specify which IP addresses and hosts have access to the X server. Port TCP/6000+n where n is the screen number. Usually n=0. Can have multiple screens. X-Windows programs include: xterm, xclock, xeyes, xroach	
F7) X Window CLI	xterm is a command line terminal. $ xterm -display 10.0.0.1:0.0
F7) X windows tools	

xdpyinfo gets the server details such as how big is the display, etc. Whether it is open-X server. xdpyinfo allows xclient on server. xwd/xwud used to take screenshots. xwd saves the screenshot. xwud displays a screen-shot. xremote takes control of a client's keyboard and mouse. There is no real standard for this

F7) x windows access control	IP-based using xhosts. xhost + is where anybody can control. MIT magic cookies. Use SSH to setup a secure tunnel to access systems.$ ssh -Y host.
F8) RPC in Linux vs Windows?	Open Network Computing RPC (ONC/RPC) is primarily used in Linux/Unix. Distributed Computing Environment RPC (DCE/RPC) is primarily used in Windows.
F8) What does RPC allow?	

	Allows a program to call a proecdure in another address space (on another host).
F8) RPC Portmapper?	Unix RPC programs have a 32-bit value and version which match to port numbers (16-bit). RPC programs have a program version and what transport TCP/UDP). Portmapper maps program number to ports. Portmapper is RPC program number 100000. Unix Portmapper is always on TCP/111 and UDP/111. Unix Portmapper is not and cannot be static. Sun Portmapper ranges from 32000 — 32999, usually. Windows Portmapper is on TCP/135. (Also uses 136 — 139). Windows portmapper assigns RPC programs first. Registry entry.
F8) RPC Program Enumeration	Can enumerate RPC programs with "rpcinfo -p".
F8) Samba	

Samba is software that allows UNIX/Linux to share resources with Windows. Provides file/print services for windows. It uses the SMB (Server Message Block) protocol. Microsoft Windows created SMB. Samba rengineered SMB. Samba cannot be an active directory. SMB runs on TCP/139 (NetBIOS over TCP) and TCP/445 (SMB over TCP/IP)

F9) SSH overview

SSH runs off TCP/22. SSH is a secure replacement for rsh, rlogin and telnet. SSH encrypts authentication and data. SSH is used in Unix, Linux and network sevices (i.e. routers, switches and firewalls). SSH typically used to log on to a remote machine and execute commands. SSH supports tunnelling, forwarding ports, X11 connections. SSH can transfer files using as-

	sociated SSH file transfer (SFTP) or secure copy (SCP) protocols.
F9) SSH version?	SSH software banner is released in the clear (when telnet into device). openSSH developed by openBSD. openSSH is most common implementation. openSSH includes both the server and client implementation.
F9) Securing SSH	Ensure the SSH type (e.g. openSSH, Sun SSH) is using latest version. Ensure SSH supports v2 only
F9) SSH Auth	Server authentciation with private key. Client authentication with private key or password.
G1) HTTP Versions?	0.9 is depreciated. (1991). 1.0 still supported. (1996). 1.1 (RFC-2016) is most common. (1997-1999)
G1) Attributes of GET request? (4)	

1) GET method encodes submission in URL e.g. http://host/script?var1=value1&var2=value2. 2) Above URL can be logged by proxy and stored in local browser cache. 3) GET method NOT SUITABLE for sensitive data. 4) GET is a safe method. It is read-only and used for retrieval.	
G1) Cookie Flag Attributes	"Domain" in cookies determine which web servers, the client will return information from. e.g. .microsoft.com applies to any website subdomain in this domain. However cannot set to suffixes only such as .com, .co.uk 2) "Path" is optional and determines under which particular resource tree, the cookie has access to. 3) "Secure" is optional and returns a cookie if over SSL only.
G1) Entity Tags	

Entity Tag (E-Tag) determines if content of URL has changed condition. If e-tags match, no need to download body content again. Entity Tag is used in browser caching

G1) Purpose of proxies? (4)-1)

Allows access to websites that client cannot access directly. For example, Client may not have access to DNS. 2) Proxies can cache responses from the server for later use. 3) Proxies can filter using whitelisting/blacklisting. 4)"Authentication" can be enforced so that random users cannot hop through the proxy. Transport Proxy is used to intercept/filter traffic. Normally used by ISP. 5) Anonymizer Proxy hides user's IP address

G1) Caching, why, techniques and limitations

Why? Stores copies of web documents. Reduces bandwidth use and time. e.g. caches patches and UNIX files. Reduces server load. 2) 1. Client Cache. All clients have cache on their browser. private cache is on disk or in memory. 2. Proxy Cache• outbound proxy, shared by a related group of people 3. Reverse Proxy Cache, Inbound proxy, User commands are effected, Web accelerator. 3) Limitations, only static content can be stored on cache (e.g. html, jpg, gif). Proxies cannot cache programs due to its dynamic behaviour (e.g. cgi, script pages). Proxies cannot cache HTTPS as it has no way of reading the encrypted text. Can store sensitive data, should be disabled (via headers Pragma and Cache-Control

G1) Reason for host header?

e.g. 'Host: www.yahoo.com' e.g. 'Host: www.yahoo.co.uk', why? because some webserver will have many virtual hosts on them so just the IP isn't enough to be accurate.	
G1) Content Length Header	Indicate the length of the body, Interesting if 2 'Content-Length' headers are used. e.g. Content-Length: 12 e.g. Content-Length: 24, In the request, some servers will get the 1st header, while some will get the second one. Attacker can use the technique of HTTP Request Smuggling.
G1) HTTP TRACE method?	Trace Method, ask the server to echo back the content of the request. Used for debugging. An attack called cross-site tracing or XST using the TRACE method. A website with malicious content could trace back the content. Recommendation: Dis-

	able the trace method. Echoes back the received request so that a client can see what (if any) changes or additions have been made by intermediate servers.
G2) Apache Web Server Characteristics	Open source web server. Often used for Linux/Unix. Windows supported. 2 major versions, 1.x and 2.x (current).
G2) Chunked Encoding Vulnerability	Buffer overflow attack for Apache (chunk-encoded HTTP request that causes Apache to use an incorrect size.)
G2) Double Decode Vuln	IIS vuln that can bypass path traversal controls. Double dot encoding can be used by to execute arbitrary. Same impact as unicode as that leads to directory traversal. e.g. Having %2F, IIS will decode it as /. However IIS performs second decoding. e.g. Decoding: %252F decodes to %2F

	and double decodes to / . So http://site-name/script/..%252F..%252F/win-nt/system32
G2) Unicode Vulnerabilities	Making the webserver decode %2F etc (/) in order to perform path traversal type vulns
G2) mod-userdir Info disclosure	Apache vuln. mod userdir Information Disclosure http://site/ ~ user. Allows user enumeration. If user not there, it will respond with user not found. (CVE-2001-1013)
G2) Win32 Batch file remote command execution	Win32 Batch file remote command execution (CVE-2002-0061) does not filter pipe character. | pipe allows to execute 2 commands. Use the pipe character | which only affected Windows version and not the Linux version.
G2) Random webserver needed to know other than Apache and IIS?	

IBM Websphere, main components is WAS (Websphere Application Server), uses open standard, it uses Java, XML, Web services. Sun Web Server, Netscape Entrprise Server (2000), bought by Sun. Renamed to iplanet (2000-2002) Sun One (2002-2003) Sun Java System Web Server (2003-2011) Oracle iPlanet Wev Server (2011-Current)	
G3) What is the 3 tiered architecture?	Scalable architecture. Standard architecture for web services. 1. Presentation = 'Web server'. 2. Application = 'Logic' (Programs that run). 3. Data = 'Database'
G4) What is SOAP?	Simple Object Access Protocol (SOAP). Based off of a pretty standard RPC call, but across the internet. SOAP uses XML and couples data and structure into a flat file. Can use different struc-

	tures/flexible. SOAP runs over HTTP, HTTPS, SMTP (any TCP/IP). Firewall friendly protocol. Takes stateless model and uses it.
G4) XML message format?	Transport message contains: "Envelope", "Header", "Body", "Fault". "Envelope" defines that a soap method is following. "Header" provides application specific information. "Body" is the data itself. "Fault" is optional and provides information about errors.
G4) WSDL?	Web Services Description Language (WSDL). XML Document specific. Location (usually IP address & Port). Operations (available functions). Message Structure and Types.
G4) UDDI?	Universal Description Discovery & Integration (UDDI). UDDI is like a directory/yellow pages for WSDL (used

	in SAP, Oracle, Microsoft). XML-based registry
G4) HTTP HEAD, PUT, TRACE and CONNECT definitions	HEADRet rieves header response only. PUT Requests that the enclosed entity be stored under the supplied URL. TRACE Echoes back the received request so that a client can see what (if any) changes or additions have been made by intermediate servers. CONNECT Converts the request connection to a transparent TCP/IP tunnel
G4) HTTP 100 Response codes	Informational, 100-Continue; 101-Switching Protocol; 102-Processing
G4) HTTP 200 Response codes	Successful, 200-OK; 201-Created; 202-Accepted; 203-Non Authoriative Info; 204-No Content; 205-Reset Content; 206-Partial Content; 207-Multi-Status; 208-Already reported;
G4) HTTP 300 Response codes	

Redirect, 300-Multiple Choices; 301-Moved Permanently; 302-Moved Temporarily; 303-See Other; 304-Not modified; 305-Use Proxy; 307-temporary Redirect	
G4) HTTP 400 Response codes	Client error, 400-Bad Request; 401-Unauthorised; 402-Payment Required; 403-Forbidden; 404-File not Found; 405-Method not allowed; 406-Not acceptable; 407-Proxy authentcation; 408-Request Timeout; 409-Conflict; 410-Gone; 411-Length Required; 412-Precondition Failed;
G4) HTTP 500 Response codes	Server error, 500-Internal Server Error; 501-(Method) not implemented; 502-Bad Gateway; 503-Service Unavailable; 504-Gateway Timeout; 505-HTTP Version not supported
	HTML is short for Hypertext Markup Language. HTML is the main markup

G5) HTML	for the web and email clients. Version 4.01 was released in 1999. W3C are working on version 5.
G5) XML	XML is short for Extenisble Markup Language. XML is a meta language and specification for creating data. In XML, can define your markup to represent your data.XML is text-based. XML forms structured data to be flattened and sent over unstructured channels. XML syntax is stricter than HTML. XML tags are same as to HTML. XML tends to be big and slow to parse. <?xml version="1.0"> represents the version and encoding.
G6) ASP	Microsoft's Scripting Language Technology. .asp extension indicate the file uses the ASP language. You can map it to HTML. .asp.net is available from IIS 6 onwards with .aspx extension.

	.asp.net has a function called 'request validation' which is a setting to prevent script injection. It is enabled by default and will filter special characters.
G6) JSP	Java Server Pages (JSP) Sun Java's Scripting Language Technology. To deploy and run JavaServer Pages, a compatible web server with a servlet container, such as Apache Tomcat or Jetty, is required.
G6) PHP	

PHP Hypertext Preprocessor (PHP) or Personal Home Page. PHP is a web scripting language. Often used by apache. PHP3 (1998), PHP4 (2000), PHP5 (2004). 2) 4 Configuration variables that should be known as a pen-tester = 1. register globals = By default, it is on, it is a setting. All input created is put into this global variable. 2. safe mode = if enabled, it restricts access to the file that runs, will be removed in PHP6. 3. open basedir = only allow to open the file under the directory, a lot better than safe mode. 4. magic quotes = try to reduce the danger of SQL by adding backslash to escape attempts from ' or ". (e.g. ' -> \', " -> \", \ -> \\). Will be Removed in PHP6. 3) register globals should be turned off. magic quotes give a false sense security. Should never use it,

should create own white list. Do not rely on magic quotes.

G6) Javascript	Javascript is a client-side scripting language. Language is run by any web browser. Not the same as Java. Javascript is inside HTML and in-lined with script tag. e.g. All browsers (opened) can read this script. 2) document.write(param) is a function that writes the value given as a parameter to the html page. alert() is a function that will pop up a dialog box and is used for testing code injection. Alert box is the usual way to prove existence of code injection. If multiple statements are required, functions need to separated by ; e.g. alert(); The literal string can single or double quotes, e.g. 'literal' and "string". + is a concatenate character.
G6) DOM	

Document Object Module (DOM). DOM is a platform and language independent interface for HTML documents allow to access and change the document on-the-fly. DOM has a object tree structure. There are a number objects include Windows, Document, etc. For document object, there is title, cookie, domain, etc. The hierarchy is separated by a dot e.g. document.cookie is a object. document.write() is a method. e.g. alert(document.cookie) and document.write(document.cookie).

G6) CGI-based Perl

Common Gateway Interface (CGI-based) Perl. Common Gateway Interface is a method for web server software to delegate the generation of web content to executable files. CGI used to be compiled C programs. Usually this is done with scripting language such as Perl, Python, Ruby and shell. Drawback: Calling a command generally means the invocation of a newly created process on the server, which consume more time and memory. FastCGI allows a single, long-running process to handle more than one user request while keeping close to the CGI programming model. Simple CGI.

G7) Ajax

Asynchronous Javascript And XML (AJAX). Allows application to retrieve data asynchronous. This means no need to wait for the first page to load-

	up. Development of interactive applications made easier. Required good Javascript support.
G7) Coldfusion	It is a web application server & scripting language. Allow creation of dynamic web title that connects to the backend db. Vulnerability in Expression Evaluator (exprcalc.cfm). exprcalc.cfm allows attackers to read and delete files remotely (CVE-1999-0455).
G7) J2EE	Java 2 Platform Enterprise Edition (J2EE). J2EE is a platform-independent, Java-centric environment from Sun for developing, building and deploying Web-based enterprise applications. J2EE platform consists of a set of services, APIs, and protocols that provide the functionality for develop-

	ing multitiered, Web-based applications. Taken over by Oracle.
G7)Ruby on Rails	Rails, is an open source full-stack web application framework for the Ruby programming language.
G7) .NET	.Net is a software framework developed by Microsoft that runs primarily on Microsoft Windows.Includes a large library and provides language interoperability (each language can use code written inother languages) across several programming languages. Programs written for the .NET Framework execute in a software environment, known as the Common Language Runtime (CLR). An application virtual machine that provides services such as security, memory management, and exception handling. The

	class library and the CLR together constitute the .NET Framework.
G8) ISAPI?	Internet Server Application Programming Interface (ISAPI). Allows developers to add on a function used by C or C++. C and C++ can cause buffer overflows if extra care is not taken. In IIS 4 & 5, used to run the same function. There are 2 types of ISAPI. (i) filters — see every request/response. (ii) extension — completely new application and does things on-the-fly. For IIS 4 & 5, always recommend to disable ISAPI as it is not necessary
G8) ISAPI Vulns?	1) ISAPI IDA & IDQ Data Leakage. Found in IIS/4.0. IDA & IDQ extensions. http://sitename/x.idq and http://sitename/x.ida It will return that it cannot find C:\inetpub\x.idq. 2) ISAPI IDQ Buffer Overflow. Buffer

	overflow in ISAPI extension using long argument in ida/idq files (CVE-2001-0500). Gives remote access on local system. Used by Code Red worm. Biggest implication for IIS.
G8) What are apache modules?	Apache comes with basic functionality, but you can add more with modules. This allows you to add, delete and edit features for your apache installation. They are pieces of software or programs that allow you to add a particular functionality to your webserver. To see what modules are installed on your server run httpd -l
G8) General pupose Apache modules	mod deflate, mod zip, mod proxy, mod rewrite.
G8) Security apache modules	mod security, mod ssl.
G8) Apache module vulns	mod userdir allows user enumeration (CVE-2001-1013). mod jk has a buffer

	overflow (CVE-2007-0774) where version <= 1.2.20 with Win32 only.
G9) WebDAV?	WEB-based Distributed Authoring and Versioning (WebDAV). HTTP Extensions allows modification/creaton/delete/write to document/web content. First seen 1996. RFC2518. Web folders (webdav) used in Windows 98 (NT/2000). Not often used nowadays. Legacy.
G9) Java	Java is a programming language developed by Sun Microsystems. Taken over by Oracle. Java is a portable language that compiled binary code. Used by web browsers and are called applets. Browser contains Java Virtual machine. Used by web servers and are called servlets. In browser, untrusted code runs in a sandbox context for security. It is better than ActiveX. For

	buffer overflow, there are automatic array bounds checking. Pure Java application tend to be more secure than PHP. JSP is a way to run applets as servlet
G9) Active X	Microsoft framework for defining reusable software components in a programming language-independent way. Internet Explorer also allows the embedding of ActiveX controls in web pages. However, ActiveX will not work on all internet platforms.
HX) Types of information available in web page source that may prove useful	Hidden Form Fields. Database Connection Strings. Credentials. Developer Comments. Other included files. Authenticated-only URLs. Client-side scripts.
HX) Web App recon techniques	

HTML source review (can use wget -r -m -nv to download all HTML source code locally, then grep for script, @, TYPE=HIDDEN, comments). Analysis of server-side file extensions (file extensions can tell you the server platform). Session ID fingerprinting (can tell you the backend technology). Active backend database technology assessment. Tools like Wikto/Nikto

HX) File Extensions To Web Server Tech?

ASP = IIS, ASPX/ASMX = IIS 5.0 or later using .NET framework, CFM = coldfusion, DO= IBM Websphere, JSP = Sun Java Server Pages (likely Unix), PHP = Generic but probs Apache, PL/PHTML = Generic but probs Unix

HX) Session ID to Webserver tech

ASPSESSIONID = IIS using ASP, ASP.NET_SessionID = Microsoft IIS using .NET Framework ASP scripting. CFID/CFTOKEN = Adobe ColdFusion. JROUTE = Sun Java System Application Serve. JSESSIONID = Various JSP engines, including Apache Tomcat, IBM WebSphere Application Server, and Caucho Resin; depending on the format of the session ID value itself, you can fingerprint the exact engine. PHPSESSID = PHP

HX) Enumerating backend databases techniques?

can be enumerated by passing erroneous data as variables to web application components, thus spawning a response that will indicate the backend database server technology. Basicly SQL injection stuff and getting version

HX) Request smuggling?	Putting multiple requests inside of each other, the backend encoding may not filter bad stuff in the 3rd/4th requests
HX) Web app auth issues	Default or guessable user accounts. HTTP form brute-force. Session management weaknesses (Weak session ID generation through obfuscation of known variables such as username, or lack of a salt when performing cryptographic hashing, Session fixation, where a new session ID is not reissued upon login, Insufficient timeout and expiration mechanisms, leading to brute-force and replay attacks)
HX) Types of command injections?	OS, SQL, LDAP and XML
	In LDAP injection, an attacker modifies a string that he knows will be processed by a backend LDAP server to form an LDAP statement. In much

HX) LDAP Injection?	the same way that attackers use SQL escape characters to execute arbitrary SQL statements server-side, they can also use LDAP characters ( ) | (*) to modify and create LDAP statements.
HX) LDAP injection vulns?	Web applications using backend LDAP servers can be exploited in several ways. The three main types of attack involve: Bypassing LDAP-based authentication mechanisms (try adding some pipes and wildcards to the uid). Reading data from the LDAP directory (try adding these:)(|(cn=*),)(|(objectclass=*),)(|(homedirectory=*). Modifying data within the LDAP directory
HX) Web app security checklist (7)	updated, input validation, secure session ID, ensure associate apache components such as mod_jk and PHP are disabled if you are not using them.

	Remove default files. Don't expose debugging info. Rule of least access.
HX) Encryption vs Encoding?	1) encoding is just an algorithm used to change data from one format to another, no key required to go backwards. It is used so that data can be safely consumed by another system (think binary). The goal is not to keep it secret but make it flow well. Encryption tries to keep things secret and requires a key to get back the plaintext.
HX) Recognise Encoded Value (Base64, UTF-8)?	First three bytes 0xEF,0xBB,0xBF is probably a UTF-8 encoded file. Base64 the length of a Base64-encoded string is always a multiple of 4. Only these characters are used by the encryption: "A" to "Z", "a" to "z", "0" to "9", "+" and "/" The end of a string can be padded up to two

	times using the "="-character. Example (dGVzdGVlZmVlZg==)
HX) Encryption for data in transit vs at rest?	Data can be exposed to risks both in transit and at rest and requires protection in both states. As such, there are multiple different approaches to protecting data in transit and at rest. Encryption plays a major role in data protection and is a popular tool for securing data both in transit and at rest. For protecting data in transit, enterprises often choose to encrypt sensitive data prior to moving and/or use encrypted connections (HTTPS, SSL, TLS, FTPS, etc) to protect the contents of data in transit. For protecting data at rest, enterprises can simply encrypt sensitive files prior to storing them and/or choose to encrypt the storage drive itself. Google uses the Advanced Encryption Standard (AES) algorithm to

	encrypt data at rest. All data at the storage level is encrypted with AES256 by default, with the exception of a small number of Persistent Disks created prior to 2015 that use AES128. AES is widely used because (1) both AES256 and AES128 are recommended by the National Institute of Standards and Technology (NIST) for long-term storage use (as of March 2019), and (2) AES is often included as part of customer compliance requirements.
HX) Source Code Review	1) Comments, 2) hardcoded creds, 3) hidden fields, 4) sensitive data exposure, 5) unvalidated redirects and forwards 6) cryptography 7) data validation
I1) Web site structure discovery (4)	1) wget -r -m -nv http://example.om 2) burp spider 3) sam spade is a windows web crawler 4) wsdl file
I2) What is XSS?	

type of code injection attack, normally using javascript. Any code that executes has accesss to all documents i.e if browser is connected to website, can use DOM	
I3) SQLi version?	@@version
I3) SQLi prevention? (5)	1) Input san 2) blacklist & whitelist 3) HTML encoding 4) parameterised queries
I3) SQLi enumerate database? (3)	SELECT, UPDATE for changing value and INSERT for creating new value
I3) SQLi execute commands? (3)	Micrsoft SQL server 1) xp_cmdshel can issue any command (EXEC master..xp.cmdshell ""--) 2) sp_makewebtask dump results of a db to HTML file (EXEC master..sp_makewebtask "\\\\out.html" ,""--) 3) xp_regread dump registry keys from the db server to obtain encrypted password strings (EXEC xp_re-

	gread 'HKLM','SECURITY\SAM\Domains\Account','c:\temp\out.txt'--)
J0) What is SQL?	Structure Query Language (SQL). A programming language used to retrieve information and modify database. SQL can be called in programming lanugages.
J0) Common SQL query statements	SELECT -- used to read from the databases. INSERT -- used to add data, add rows to table. UPDATE -- used to change/modify data. DELETE -- used to delete from database.
J0) SQL comments	-- comments (Mostly SQL Server). # This comment continues to end of line. -- This comment continues to end of line. mySQL requires a space after --. /* This is the SQL DB standard in-line comment */ REM, @ Line starting with REM or @ are comments in Oracle.
J1) MS SQL vs Sybase	

SQL Server was developed from Sybase. There was a deal to share the source code with Microsoft. Until version 4.9, Sybase and SQL Server were virtual identical. Disagreements lead to split of code-lines. According microsoft, there is no sybase code in their latest version of SQL server. Investment banking still like to use Sybase. Tabular Data Stream (TDS) is an application level protocol used to transfer data between a database server and a client. Initially designed and developed by Sybase Inc. for their Sybase SQL Server relational database engine in 1984, and later by Microsoft in Microsoft SQL Server.

J1) MS SQL Port general info? (port, modes, auth, encryption)

1) SQL Server runs off TCP/1433. SQL Server Monitor runs off UDP/1434. Monitor used to get system status. Monitor can send instance name or version of SQL instance/TCP port instance is listening on. 2) During installation, there is a mode called "hidden mode". SQL Server runs from TCP/2433. In "hidden mode", no broadcast can be set and UDP will not respond to broadcasts. 3) Authentication Methods, Windows = Authentication against operating system only using a windows domain/active directory. Mixed Mode = Windows / SQL Server. It uses TCP/1433 for authentication and logging in. 4) Encryption = Traffic encryption NOT database encryption. No encryption by default. There is an optional SSL encryp-

tion that requires server-side certificate and extra configuration work.	
J1) MS SQL default accounts	SA account will be created, SA is the database owner/superuser. SQL 2000 has a blank password set for SA by default. SQL 2005 doesn't have that set. Could try username and password as SA. Never use database owner (SA) account to do any transactions
J1) MS SQL Tools	sql (obsolete). osql (came with SQL 2000. still works. replaced by sqlcmd. osql client commands can be downloaded). sqlcmd (came with SQL 2005). sqsh (sql shell, only available for linux). sqlping (Windows)
J1) What are stored procedures and which ones are present in MS SQL?	Stored Procedures are functions that run on DB Server. 2) Standard/System Stored Procedures (sp *) e.g. sp addrecord, sp tables. Extended Stored Procedures (xp *) e.g. xp cmdshell

J1) MS SQL execute a query?	type 'go' after it
J1) Common MS SQL queries (8)	1) SELECT @@version; = Version Info. 2) EXEC sp databases; = Show Database Instances. 3) EXEC sp helpdb ; = Show Database Description. 4) USE ; = Select Database Instance. 5) EXEC sp tables; = Show Tables. 6) EXEC master..xp cmdshell 'cmd'; = Run OS command. 7) SELECT name,password from master.dbo.sysxlogins; = Display password hashes. 8) SELECT * from ;
J1) What is MSDE?	MSDE (Microsoft SQL Server Desktop Engine) (SQL Server 2000). Used as a cut down version of SQL Server. It is bundled without software products. No Configuration, SA password is always blank. Obsolete. Replaced by SQL Server Express.
J2) RDBMS?	Oracle Relational Database Management System
J2) TNS Listener	

TNS Listener runs on tcp/1521. TNS Listener allows anyone to connect without password. Version and configuration can be leaked. Can use "tnscmd" tool. Use scanner/oracle/tnslsnr version (Metasploit). Use scanner/oracle/sid enum (Metasploit)	
J2) Oracle Default Accounts	1) SYS:CHANGE_ON_INSTALL. 2) SYSTEM:MANAGER 3) DBSNMP:DBSNMP 4)SYSADM:SYSADM 5)SCOTT:TIGER 6) OUTLN:OUTLN 7) MDSYS:MDSYS
J2) Oracle Queries (10)	

1) SELECT * FROM v$version; = Show Version. 2) SELECT * FROM product component version; = Show Version. 3) SELECT username,password from dba users; = Show Database User/Password. Obsolete in 11g. 4) SELECT name,password FROM SYS.USER$ WHERE password is not null; = Show Database User/Password DES Hash (up to 10g). SELECT name,spare4 FROM SYS.USER$ WHERE password is not null; = Show Database User/-Password SHA-1 Hash (up to 10g_. 5) SELECT * FROM all users; 6) SELECT * FROM v$database; 7) SELECT * FROM v$instance; 8) SELECT owner, table name FROM all tables; 9) SELECT owner, table name FROM dba tables; 10) SELECT table name FROM user tables;

J2) Where are passwords stored in Oracle?

Hashes are stored in a table called SYS.USERS$. SELECT USERNAME,PASSWORD, ACCOUNT STATUS FROM DBA USERS; e.g. use DBSNMP because it is likely to be available.	
J2) Oracle database instances	Oracle defines database instances as SIDs. Different groups of users have different access rights for different DB instances. Good user/database segregation
J2) Tools	Oracle SQL Developer. Oscanner. SQL Tools. tnscmd
J3) mySQL	Most installations are on Unix/Linux. There is a Windows version. By default, listens on TCP/3306.
J3) mySQL accounts	Default account is 'root' with no password. root can only connect from local host in latest version, even though root/blank password is default.

J3) % in SQL	% is a SQL wildcard.
J3) mySQL tools	mySQL Client. To find the version of mySQL client running locally:$ mysql --help. $ mysql -? . To find the version of mySQL server running locally: $ mysqld -v
J3) mySQL useful queries	In mySQL, there is no need to type go. But all queries need to end with a semicolon ; 2) To find the version of mySQL server running remotely through the mySQL client:> select version();> select user();> show databases;> show tables from ;> select host, user, password from user; 3) The last query only shows the hashes and not the plain text password. 4) A password hash cracker is required.
	Another open source DB. It uses TCP/5432 (UDP/5432). It is an object-relational database management

J3) PostGresql	system (ORDBMS). Postgres supports transaction integrity whereas mySQL does not. Postgres supports views, stored procedures, triggers, etc
J3) ODBC	A software API that uses database. Independent layer between application and database. Main advantage is the application can be independent to the DB. DB system is independent (can use any db server). Operating System (OS) is independent (e.g. Windows, Linux, Mac). Programming lanaguage is independent (e.g. Ruby, VB, PHP, etc). Java calls it, JDBC.
J3) DB2	IBM Websphere is likely to be using DB2. It may use: TCP/523, UDP/523, TCP/6789, TCP/6790.
J3) Teradata	Teradata RDBMS is a massively parallel processing system. Ideal for huge data warehousing. (e.g. for billing

	data, supplier data and combinations). It uses TCP/8002 (UDP/8002)
J3) SQLi tools	SQLMap. SQLNinj